

BÁO CÁO THỰC HÀNH

Môn học: Bảo mật Web và Ứng dụng

Lab 3: Reconnaissance

GVHD: Ngô Khánh Khoa

Nhóm: 11

1. THÔNG TIN CHUNG:

Lớp: NT213.P11.ANTT.2

STT	Họ và tên	MSSV	Email
1	Nguyễn Đặng Quỳnh Như	22521050	22521050@gm.uit.edu.vn
2	Phạm Minh Tân	22521310	22521310@gm.uit.edu.vn
3	Lê Minh Quân	22521181	22521181@gm.uit.edu.vn
4	Đặng Đức Tài	22521270	22521270@gm.uit.edu.vn

2. NỘI DUNG THỰC HIỆN:

STT	Nội dung	Tình trạng	Trang
1	Bài tập cơ bản (15 bài)	15/15	2
2	Bài tập thực hành	2/2	21
3	Tryhackme	8/8	23
4	Hackthebox	7/8	37
Điểm tự đánh giá			10/10

Link video youtube: [Click here](#)

Phần bên dưới của báo cáo này là tài liệu báo cáo chi tiết của nhóm thực hiện

BÁO CÁO CHI TIẾT

PHẦN I. BÀI TẬP CƠ BẢN

Bài 1: Thực hiện lệnh WHOIS lookup với tên miền indriver.com

```
(dducktai@kali) ~  
$ whois indriver.com  
  
Domain Name: INDRIVER.COM  
Registry Domain ID: 130600645_DOMAIN_COM-VRSN  
Registrar WHOIS Server: whois.corporatedomains.com  
Registrar URL: http://cscdbs.com  
Updated Date: 2024-08-26T14:18:16Z  
Creation Date: 2004-09-21T21:01:04Z  
Registry Expiry Date: 2025-09-21T21:01:04Z  
Registrar: CSC Corporate Domains, Inc.  
Registrar IANA ID: 299  
Registrar Abuse Contact Email: domainabuse@cscglobal.com  
Registrar Abuse Contact Phone: 8887802723  
Domain Status: clientTransferProhibited https://icann.org/epp#clientTransferProhibited  
Name Server: NS-1336.AWSDNS-39.ORG  
Name Server: NS-1696.AWSDNS-20.CO.UK  
Name Server: NS-294.AWSDNS-36.COM  
Name Server: NS-621.AWSDNS-13.NET  
DNSSEC: unsigned  
URL of the ICANN Whois Inaccuracy Complaint Form: https://www.icann.org/wicf/  
>>> Last update of whois database: 2024-11-20T08:46:18Z <<<  
  
For more information on Whois status codes, please visit https://icann.org/epp  
  
NOTICE: The expiration date displayed in this record is the date the  
registrar's sponsorship of the domain name registration in the registry is  
currently set to expire. This date does not necessarily reflect the expiration  
date of the domain name registrant's agreement with the sponsoring  
registrar. Users may consult the sponsoring registrar's Whois database to  
view the registrar's reported date of expiration for this registration.  
  
TERMS OF USE: You are not authorized to access or query our Whois  
database through the use of electronic processes that are high-volume and  
may扰乱 domain names or modify existing registrations. VeriSign reserves the right  
to restrict your access to the Whois database in its sole discretion to ensure  
operational stability. VeriSign may restrict or terminate your access to the  
Whois database for failure to abide by these terms of use. VeriSign  
reserves the right to modify these terms at any time.  
  
The Registry database contains ONLY .COM, .NET, .EDU domains and  
Registrars.  
  
Domain Name: indriver.com  
Registry Domain ID: 130600645_DOMAIN_COM-VRSN  
Registrar WHOIS Server: whois.corporatedomains.com  
Registrar URL: www.cscprotectsbrands.com  
Updated Date: 2024-08-26T10:18:16Z  
Creation Date: 2004-09-21T17:01:04Z  
Registrar Registration Expiration Date: 2025-09-21T21:01:04Z  
Registrar: CSC CORPORATE DOMAINS, INC.  
Sponsoring Registrar IANA ID: 299  
Registrar Abuse Contact Email: domainabuse@cscglobal.com  
Registrar Abuse Contact Phone: +1.8887802723  
Domain Status: clientTransferProhibited http://www.icann.org/epp#clientTransferProhibited  
Registry Registrant ID:  
Registrant Name: Domain Manager  
Registrant Organization: SUOL INNOVATIONS LTD  
Registrant Street: 41 Themistokli Dervi, Hawaii Tower, 1ST Floor, Office 106  
Registrant City: Nicosia  
Registrant State/Province: Nicosia  
Registrant Postal Code: 1066  
Registrant Country: CY  
Registrant Phone: +357.22667730  
Registrant Phone Ext:  
Registrant Fax: +357.22667740  
Registrant Fax Ext:  
Registrant Email: domainmaster@indriver.com  
Registry Admin ID:  
Admin Name: Domain Manager
```

Id của IANA của tên miền trên là gì?

⇒ IANA ID của Registrar là **299** (CSC Corporate Domains, Inc.).

Tên miền trên được đăng ký khi nào?

⇒ Tên miền indriver.com được đăng ký vào **ngày 21 tháng 9, 2004**.

Registrar của tên miền trên là?

⇒ Registrar của tên miền indriver.com là **CSC Corporate Domains, Inc.**

Công ty nào được sử dụng cho dịch vụ Name Server?

⇒ Các máy chủ DNS được sử dụng là:

- **ns-294.awsdns-36.com**
- **ns-1696.awsdns-20.co.uk**
- **ns-1336.awsdns-39.org**
- **ns-621.awsdns-13.net**

Địa chỉ admin contact email cho tên miền trên là?⇒ Email của admin contact là domainmaster@indriver.com

Bài 2: So sánh kết quả khi thực hiện *nslookup* và *dig* với loại query là *mx* với tên miền *indriver.com*, thông tin nào được cung cấp thêm bởi lệnh *DIG*, ý nghĩa các thông tin đó như thế nào

Sử dụng dig:

```
(dducktai@kali)-[~]
$ dig @8.8.8.8 indriver.com MX

; <<>> DiG 9.20.0-Debian <<>> @8.8.8.8 indriver.com MX
; (1 server found)
;; global options: +cmd
;; Got answer:
;; ->>HEADER<<- opcode: QUERY, status: NOERROR, id: 53404
;; flags: qr rd ra; QUERY: 1, ANSWER: 5, AUTHORITY: 0, ADDITIONAL: 1

;; OPT PSEUDOSECTION:
;; EDNS: version: 0, flags:; udp: 512
;; QUESTION SECTION:
;indriver.com.                IN      MX

;; ANSWER SECTION:
indriver.com.                300     IN      MX      12 alt2.aspmx.l.google.com.
indriver.com.                300     IN      MX      14 alt4.aspmx.l.google.com.
indriver.com.                300     IN      MX      10 aspmx.l.google.com.
indriver.com.                300     IN      MX      11 alt1.aspmx.l.google.com.
indriver.com.                300     IN      MX      13 alt3.aspmx.l.google.com.

;; Query time: 48 msec
;; SERVER: 8.8.8.8#53(8.8.8.8) (UDP)
;; WHEN: Fri Nov 08 03:03:31 CET 2024
;; MSG SIZE rcvd: 156
```

Sử dụng nslookup:

```
(dducktai@kali) - [~]  
$ nslookup -query=mx indriver.com  
  
Server:      192.168.31.2  
Address:     192.168.31.2#53  
  
Non-authoritative answer:  
indriver.com mail exchanger = 11 alt1.aspmx.l.google.com.  
indriver.com mail exchanger = 10 aspmx.l.google.com.  
indriver.com mail exchanger = 13 alt3.aspmx.l.google.com.  
indriver.com mail exchanger = 14 alt4.aspmx.l.google.com.  
indriver.com mail exchanger = 12 alt2.aspmx.l.google.com.  
  
Authoritative answers can be found from:  
alt2.aspmx.l.google.com internet address = 142.250.115.27  
aspmx.l.google.com      internet address = 64.233.188.27  
alt1.aspmx.l.google.com internet address = 142.250.141.27  
alt2.aspmx.l.google.com has AAAA address 2607:f8b0:4023:1004::1a  
aspmx.l.google.com      has AAAA address 2404:6800:4008:c05::1a  
alt1.aspmx.l.google.com has AAAA address 2607:f8b0:4023:c0b::1b
```

So sánh ns lookup và dig:

- **nslookup** sẽ trả về các thông tin cơ bản về các bản ghi MX, chẳng hạn như tên máy chủ và độ ưu tiên (priority). Thông tin bổ sung IPv4 và IPv6 của các máy chủ MX được cung cấp trong phần **Authoritative answers**.

- **dig** cũng trả về danh sách các máy chủ MX của **indriver.com**, nhưng không cung cấp thông tin chi tiết về IPv4 hoặc IPv6. Ngoài ra, dig cung cấp thêm thông tin như sau:

- + **EDNS** cho phép DNS hỗ trợ các tính năng mở rộng như hỗ trợ truy vấn lớn hơn (trên 512 bytes), giúp cải thiện khả năng mở rộng của DNS. Cung cấp các thông số như version: 0 và flags: (trạng thái các cờ của EDNS).
- + **TTL (Time to Live)**: Thời gian tồn tại của bản ghi DNS trước khi nó cần được làm mới.
- + **CLASS**: Lớp của bản ghi DNS (thường là IN cho Internet).
- + **Query Time**: Cung cấp thời gian thực hiện truy vấn DNS, cho thấy độ trễ khi thực hiện truy vấn (48 ms)
- + **ANSWER SECTION**: Phần chi tiết hơn về các bản ghi MX, cung cấp thông tin về tên miền và độ ưu tiên, giúp bạn hiểu rõ hơn về cấu trúc DNS của tên miền.

Bài 3: *Thực hiện truy vấn IP với tên miền indriver.com. Địa chỉ IP nào map với indriver.com? Tên miền nào trỏ đến địa chỉ 134.209.24.248? Mail server nào liên quan đến tên miền indriver.com?*

Truy Vấn Địa Chỉ IP Của Tên Miền indriver.com

Để tìm địa chỉ IP của tên miền indriver.com, chúng ta có thể sử dụng các công cụ như nslookup hoặc dig, là những công cụ phổ biến giúp truy vấn DNS:

```
nguyendangquynhnhu@nguyendangquynhnhu-VMware-Virtual-Platform:~$ nslookup indriver.com
Server:          127.0.0.53
Address:         127.0.0.53#53

Non-authoritative answer:
Name:   indriver.com
Address: 13.35.185.125
Name:   indriver.com
Address: 13.35.185.18
Name:   indriver.com
Address: 13.35.185.11
Name:   indriver.com
Address: 13.35.185.74
```

Tên Miền Trỏ Đến Địa Chỉ IP 134.209.24.248

Để tìm các tên miền nào trỏ đến một địa chỉ IP cụ thể, trong trường hợp này là 134.209.24.248, chúng ta sử dụng lệnh dig với tham số -x để thực hiện truy vấn ngược (Reverse DNS Lookup):

```
nguyendangquynhnhu@nguyendangquynhnhu-VMware-Virtual-Platform:~$ dig -x 134.209.24.248

; <<>> DiG 9.18.28-0ubuntu0.24.04.1-Ubuntu <<>> -x 134.209.24.248
;; global options: +cmd
;; Got answer:
;; ->>HEADER<<- opcode: QUERY, status: NOERROR, id: 55274
;; flags: qr rd ra; QUERY: 1, ANSWER: 1, AUTHORITY: 0, ADDITIONAL: 1

;; OPT PSEUDOSECTION:
;; EDNS: version: 0, flags:; udp: 65494
;; QUESTION SECTION:
;248.24.209.134.in-addr.arpa. IN PTR

;; ANSWER SECTION:
248.24.209.134.in-addr.arpa. 5 IN PTR inlanefreight.com.

;; Query time: 115 msec
;; SERVER: 127.0.0.53#53(127.0.0.53) (UDP)
;; WHEN: Thu Nov 07 22:32:38 AST 2024
;; MSG SIZE rcvd: 87
```

Truy Vấn Các Máy Chủ Mail (MX Records) của Tên Miền indriver.com

Để xác định máy chủ mail liên quan đến tên miền indriver.com, chúng ta sử dụng lệnh dig với loại truy vấn MX:

```
nguyendangquynhnhu@nguyendangquynhnhu-VMware-Virtual-Platform:~$ dig mx indriver.com

;<><> DiG 9.18.28-0ubuntu0.24.04.1-Ubuntu <><> mx indriver.com
;; global options: +cmd
;; Got answer:
;; ->HEADER<<- opcode: QUERY, status: NOERROR, id: 62619
;; flags: qr rd ra; QUERY: 1, ANSWER: 5, AUTHORITY: 0, ADDITIONAL: 1

;; OPT PSEUDOSECTION:
; EDNS: version: 0, flags:; udp: 65494
;; QUESTION SECTION:
;indriver.com.                IN      MX

;; ANSWER SECTION:
indriver.com.                5      IN      MX      13 alt3.aspmx.l.google.com.
indriver.com.                5      IN      MX      12 alt2.aspmx.l.google.com.
indriver.com.                5      IN      MX      14 alt4.aspmx.l.google.com.
indriver.com.                5      IN      MX      11 alt1.aspmx.l.google.com.
indriver.com.                5      IN      MX      10 aspmx.l.google.com.

;; Query time: 13 msec
;; SERVER: 127.0.0.53#53(127.0.0.53) (UDP)
;; WHEN: Thu Nov 07 22:32:55 AST 2024
;; MSG SIZE rcvd: 156
```

Bài 4: *Liệt kê các tên miền phụ của indriver.com, kết quả được lưu trong file CSV.*

Sử dụng công cụ Sublist3r:

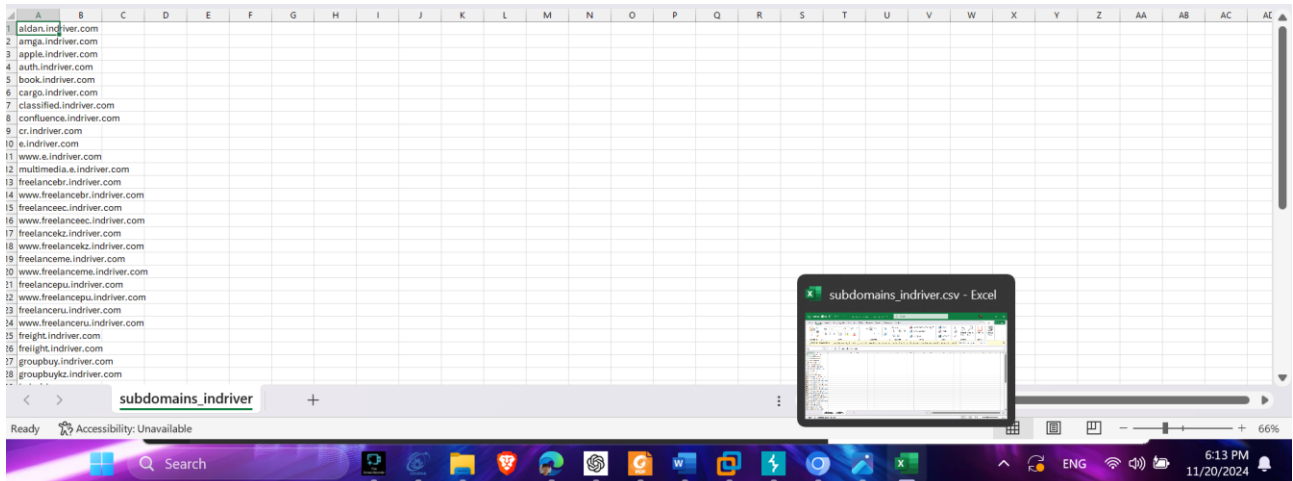
```
dducktai@kali:~$ sublist3r -d indriver.com -o subdomains_indriver.csv

Sublist3r
# Coded By Ahmed Aboul-Ela - @aboul3la

[-] Enumerating subdomains now for indriver.com
[-] Searching now in Baidu..
[-] Searching now in Yahoo..
[-] Searching now in Google..
[-] Searching now in Bing..
[-] Searching now in Ask..
[-] Searching now in Natcraft..
[-] Searching now in DNSDumpster..
[-] Searching now in Virustotal..
[-] Searching now in ThreatCrowd..
[-] Searching now in SSL Certificates..
[-] Searching now in PassiveDNS..
Process DNSDumpster-8
Traceback (most recent call last):
  File "/usr/lib/python3.12/multiprocessing/process.py", line 314, in _bootstrap
    self.run()
  File "/usr/lib/python3/dist-packages/sublist3r.py", line 269, in run
    domain_list = self.enumerate()
  File "/usr/lib/python3/dist-packages/sublist3r.py", line 649, in enumerate
    token = self.get_csrf_token(resp)
  File "/usr/lib/python3/dist-packages/sublist3r.py", line 644, in get_csrf_token
    token = csrf_regex.findall(resp)[0]
IndexError: list index out of range

[-] Error: Google probably now is blocking our requests
[-] Finished now the Google Enumeration ..
[-] Error: Vauxtotal probably now is blocking our requests
[-] Saving results to file: subdomains_indriver.csv
[-] Total Unique Subdomains Found: 52
www.indriver.com
aldan.indriver.com
amga.indriver.com
apple.indriver.com
auth.indriver.com
book.indriver.com
cargo.indriver.com
classified.indriver.com
confluence.indriver.com
cr.indriver.com
e.indriver.com
www.e.indriver.com
multimedia.e.indriver.com
freelancebr.indriver.com
www.freelancebr.indriver.com
freelanceec.indriver.com
www.freelanceec.indriver.com
freelancekz.indriver.com
www.freelancekz.indriver.com
freelancecw.indriver.com
www.freelancecw.indriver.com
freelancepu.indriver.com
www.freelancepu.indriver.com
freelancecv.indriver.com
www.freelancecv.indriver.com
freight.indriver.com
freight.indriver.com
grouppuyz.indriver.com
grouppuykz.indriver.com
ic.indriver.com
injob.indriver.com
intercity.indriver.com
jira.indriver.com
job.indriver.com
www.job.indriver.com
lens.indriver.com
onedayoffer.indriver.com
pagerduty.indriver.com
promo.indriver.com
rd.indriver.com
recon.indriver.com
redmine.indriver.com
registration.indriver.com
s3-kz.indriver.com
console.s3-kz.indriver.com
services.indriver.com
share.indriver.com
sharetrip.indriver.com
sn.indriver.com
stat.indriver.com
teammate.indriver.com
url-checker.indriver.com
```

Kết quả được lưu trong file subdomains_indriver.csv (khi mở bằng Excel):



Bài 5: *Dựa vào các tên miền phụ đã tìm kiếm được ở bài tập 1 và các tên miền đã bruteforce được thêm bằng burpsuite intruder. Phân loại các tên miền có kết quả trả về status code 200 và các tên miền có kết quả trả về khác.*

Danh sách tên miền đã tìm được:

ww.indriver.com	multimedia.e.indriver.com	www.freelanceru.indriver.com	onedayoffer.indriver.com
aldan.indriver.com	freelancebr.indriver.com	m	pagerduty.indriver.com
amga.indriver.com	www.freelancebr.indriver.com	freight.indriver.com	promo.indriver.com
apple.indriver.com	freelanceec.indriver.com	freiight.indriver.com	rd.indriver.com
auth.indriver.com	www.freelanceec.indriver.com	groupbuy.indriver.com	recom.indriver.com
book.indriver.com	freelancecz.indriver.com	groupbuykz.indriver.com	redmine.indriver.com
cargo.indriver.com	www.freelancecz.indriver.com	ic.indriver.com	registration.indriver.com
classified.indriver.com	freelanceme.indriver.com	injob.indriver.com	s3-kz.indriver.com
confluence.indriver.com	www.freelanceme.indriver.com	intercity.indriver.com	console.s3-kz.indriver.com
cr.indriver.com	freelancepu.indriver.com	jira.indriver.com	services.indriver.com
e.indriver.com	www.freelancepu.indriver.com	job.indriver.com	share.indriver.com
www.e.indriver.com	freelanceru.indriver.com	www.job.indriver.com	sharetrip.indriver.com
teammate.indriver.com	sm.indriver.com	lena.indriver.com	stat.indriver.com
			url-checker.indriver.com

Phân loại tên miền:

2. Intruder attack of https://5indrive.com

Attack Save

Results Positions

Intruder attack results filter: Showing all items

Request	Payload	Target	Status code	Response received	Error	Timeout	Length	Comment
38	pagerduty.indriver.com	https://pagerduty.indriver.com	200	30			1991	
52	url-checker.indriver.com	https://url-checker.indriver.com	200	295			1318	
6	book.indriver.com	https://book.indriver.com	301	132			387	
7	cargo.indriver.com	https://cargo.indriver.com	301	186			574	
26	freight.indriver.com	https://freight.indriver.com	301	443			576	
31	injob.indriver.com	https://injob.indriver.com	301	369			567	
34	job.indriver.com	https://job.indriver.com	301	191			572	
39	promo.indriver.com	https://promo.indriver.com	301	367			574	
48	sharetrip.indriver.com	https://sharetrip.indriver.com	301	470			578	
51	teammate.indriver.com	https://teammate.indriver.com	301	254			347	
1	www.indriver.com	https://www.indriver.com	302	551			533	
0		https://indrive.com	307	456			381	
4	apple.indriver.com	https://apple.indriver.com	403	385			14850	
36	lena.indriver.com	https://lena.indriver.com	403	343			14850	
42	redmine.indriver.com	https://redmine.indriver.com	403	373			14850	
47	share.indriver.com	https://share.indriver.com	403	39			4858	
49	sm.indriver.com	https://sm.indriver.com	404	447			915	
2	aldan.indriver.com	https://aldan.indriver.com		0				
3	amga.indriver.com	https://amga.indriver.com		0				
5	auth.indriver.com	https://auth.indriver.com		0				
8	classified.indriver.com	https://classified.indriver.com		0				
9	confluence.indriver.com	https://confluence.indriver.com		0				
10	cr.indriver.com	https://cr.indriver.com		0				
11	e.indriver.com	https://e.indriver.com		0				
12	www.e.indriver.com	https://www.e.indriver.com		0				
13	multimedia.e.indriver.com	https://multimedia.e.indriver.com		0				
14	freelancebr.indriver.com	https://freelancebr.indriver.com		0				
15	www.freelancebr.indriver.com	https://www.freelancebr.indriver.com		0				

Status code:

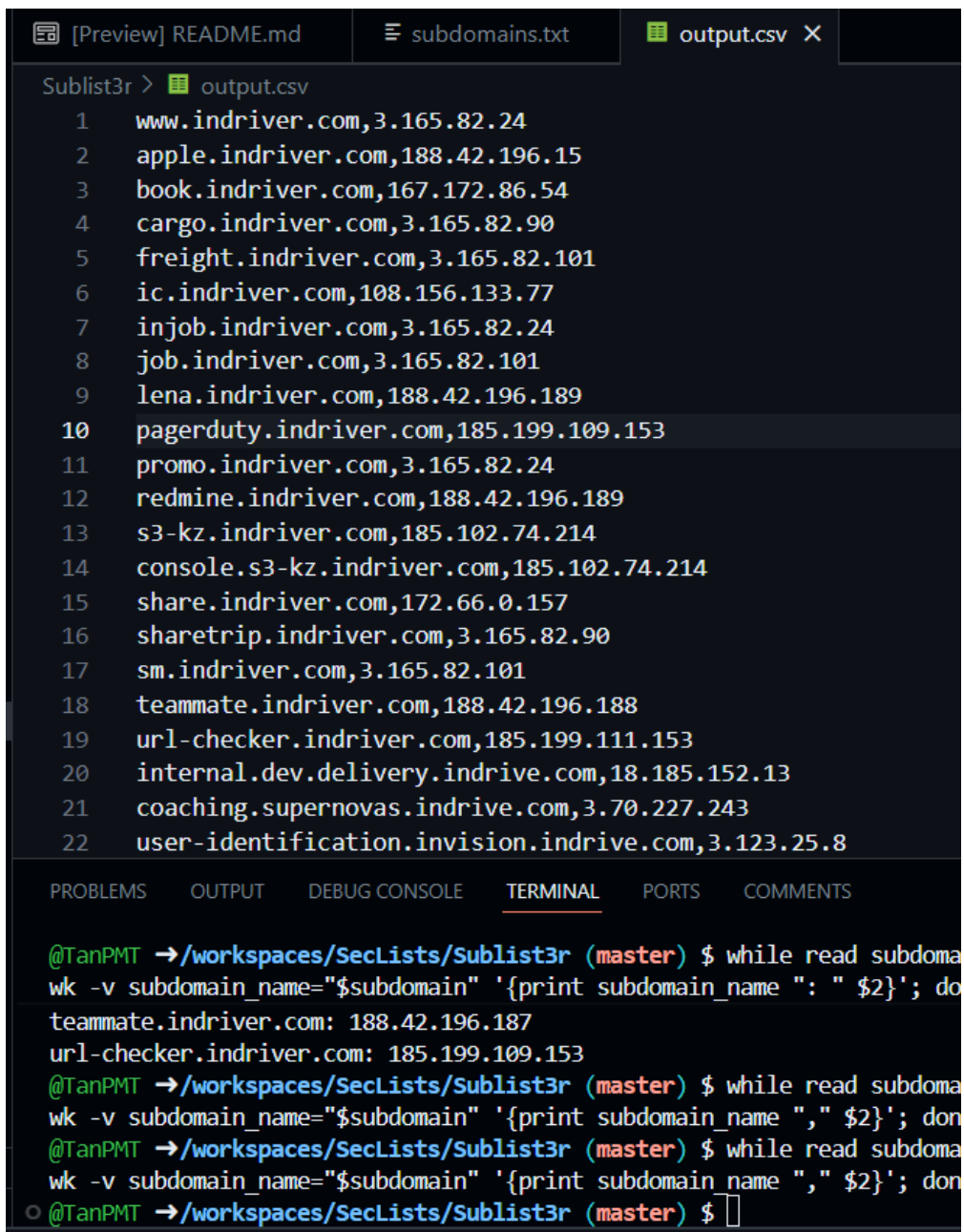
- + 200: Yêu cầu đã thành công và server đã gửi về kết quả mong đợi
- + 301: URL đã được chuyển hướng vĩnh viễn đến một URL mới
- + 302: Tài nguyên được tìm thấy nhưng tại một URL tạm thời
- + 403: Server từ chối cung cấp tài nguyên, dù yêu cầu có hợp lệ
- + 404: Server không tìm thấy tài nguyên được yêu cầu

Bài 6: Ghi nhận lại các địa chỉ IP của tên miền phụ tìm được của *.indriver.com. Kết quả lưu trong file csv

Đọc tên miền từ file subdomains.txt, dùng nslookup để dò ip

```
@TanPMT →/workspaces/SecLists/Sublist3r (master) $ while read subdomain; do nslookup $subdomain | grep 'Address' | sed -n '2p' | awk -v subdomain_name="$subdomain" '{print subdomain_name " ", $2}'; done < subdomains.txt > output.csv
```


File csv:



The screenshot shows the Sublist3r application interface. At the top, there are tabs for [Preview] README.md, subdomains.txt, and output.csv. The main window displays a list of subdomains and their corresponding IP addresses, numbered 1 through 22. Below the list, there are tabs for PROBLEMS, OUTPUT, DEBUG CONSOLE, TERMINAL, PORTS, and COMMENTS. The TERMINAL tab is active, showing the command prompt and the output of the Sublist3r command.

```
Sublist3r > output.csv
1 www.indriver.com,3.165.82.24
2 apple.indriver.com,188.42.196.15
3 book.indriver.com,167.172.86.54
4 cargo.indriver.com,3.165.82.90
5 freight.indriver.com,3.165.82.101
6 ic.indriver.com,108.156.133.77
7 injob.indriver.com,3.165.82.24
8 job.indriver.com,3.165.82.101
9 lena.indriver.com,188.42.196.189
10 pagerduty.indriver.com,185.199.109.153
11 promo.indriver.com,3.165.82.24
12 redmine.indriver.com,188.42.196.189
13 s3-kz.indriver.com,185.102.74.214
14 console.s3-kz.indriver.com,185.102.74.214
15 share.indriver.com,172.66.0.157
16 sharetrip.indriver.com,3.165.82.90
17 sm.indriver.com,3.165.82.101
18 teammate.indriver.com,188.42.196.188
19 url-checker.indriver.com,185.199.111.153
20 internal.dev.delivery.indrive.com,18.185.152.13
21 coaching.supernovas.indrive.com,3.70.227.243
22 user-identification.invision.indrive.com,3.123.25.8

PROBLEMS OUTPUT DEBUG CONSOLE TERMINAL PORTS COMMENTS

@TanPMT →/workspaces/SecLists/Sublist3r (master) $ while read subdomain; do
wk -v subdomain_name="$subdomain" '{print subdomain_name ": " $2}'; done
teammate.indriver.com: 188.42.196.187
url-checker.indriver.com: 185.199.109.153
@TanPMT →/workspaces/SecLists/Sublist3r (master) $ while read subdomain; do
wk -v subdomain_name="$subdomain" '{print subdomain_name "," $2}'; done
@TanPMT →/workspaces/SecLists/Sublist3r (master) $ while read subdomain; do
wk -v subdomain_name="$subdomain" '{print subdomain name "," $2}'; done
@TanPMT →/workspaces/SecLists/Sublist3r (master) $
```

Nội dung csv:

www.indriver.com,3.165.82.24	analytics.indrive.com,34.149.86.174
apple.indriver.com,188.42.196.15	updrive.indrive.com,65.0.79.182
book.indriver.com,167.172.86.54	dxy.indrive.com,13.234.100.116
cargo.indriver.com,3.165.82.90	money.indrive.com,35.71.142.77
freight.indriver.com,3.165.82.101	inapps2.indrive.com,65.0.79.182
ic.indriver.com,108.156.133.77	yourpace.indrive.com,13.234.100.116
injob.indriver.com,3.165.82.24	www.yourpace.indrive.com,13.234.100.116
job.indriver.com,3.165.82.101	www.updrive.indrive.com,13.234.100.116
lena.indriver.com,188.42.196.189	cr.indrive.com,65.0.79.182

pagerduty.indriver.com,185.199.109.153	ic.indrive.com,65.0.79.182
promo.indriver.com,3.165.82.24	ref.indrive.com,13.200.123.229
redmine.indriver.com,188.42.196.189	sparklab.indrive.com,65.0.79.182
s3-kz.indriver.com,185.102.74.214	beginit.indrive.com,13.200.123.229
console.s3-kz.indriver.com,185.102.74.214	www.sparklab.indrive.com,65.0.79.182
share.indriver.com,172.66.0.157	inapps.indrive.com,13.200.123.229
sharetrip.indriver.com,3.165.82.90	birthday.indrive.com,13.234.100.116
sm.indriver.com,3.165.82.101	internal.qa.delivery.indrive.com,18.185.152.13
teammate.indriver.com,188.42.196.188	intercity.indrive.com,108.156.133.42
url-checker.indriver.com,185.199.111.153	inapps3.indrive.com,65.0.79.182
internal.dev.delivery.indrive.com,18.185.152.13	promotion.indrive.com,13.200.123.229
coaching.supernovas.indrive.com,3.70.227.243	www.lp-services.indrive.com,13.200.123.229
user-identification.invision.indrive.com,3.123.25.8	sharetrip.indrive.com,108.156.133.116
raqmet.indrive.com,3.126.187.219	www.beginit.indrive.com,13.200.123.229
media.indrive.com,13.225.4.115	www.supernovas.indrive.com,13.234.100.116
www.intercity.indrive.com,108.156.133.77	fr.indrive.com,13.200.123.229
injob.indrive.com,3.165.82.101	landing.indrive.com,65.0.79.182
ventures.indrive.com,3.165.82.80	freight.indrive.com,77.220.207.191
cargo.indrive.com,13.227.254.88	promo.indrive.com,77.220.207.191
rabota.indrive.com,3.165.82.24	internal.tpl.delivery.indrive.com,13.33.88.29
www.indrive.com,13.225.4.35	internal.delivery.indrive.com,13.33.88.40
empleo.indrive.com,3.165.82.101	tpl.delivery.indrive.com,13.33.88.57
us.indrive.com,3.165.82.24	couriers.indrive.com,108.156.133.21
job.indrive.com,3.165.82.101	movie.indrive.com,167.172.86.54
careers.indrive.com,3.165.82.7	id.indrive.com,167.172.86.54
supernovas.indrive.com,13.234.100.116	www.id.indrive.com,167.172.86.54
lp-services.indrive.com,13.234.100.116	share.indrive.com,172.66.0.157
url-checker.indrive.com,3.165.82.101	rd.indrive.com,185.215.4.20
services.indrive.com,13.35.210.115	book.indrive.com,213.130.74.49
s.indrive.com,18.155.68.77	www.book.indrive.com,213.130.74.49
internal.sandbox.delivery.indrive.com,13.33.28.117	www.delivery.indrive.com,213.130.74.100
compliance.indrive.com,3.165.82.80	delivery.indrive.com,213.130.74.100
	sgtm.indrive.com,216.239.36.21

Bài 7: *Brute-force các vhosts với trang web indriver.com, có tên miền nào trả về status-code 200 không?*

- Sử dụng câu lệnh ffuf để scan tất cả các subdomain của tên miền indriver.com từ wordlist
- Sử dụng câu lệnh grep -v ("Status: 403") để lọc bỏ ra các tên miền trả về status code 403.

```
quanl@quanl:~/Documents/bmw/lab$ ffuf -w subdomains-top1million-110000.txt:FUZZ -u http://indriver.com -H 'Host: FUZZ.indriver.com' | grep -v "Status: 403"
```

```
      _____  
     /_ _ \_____/_____\n    /   /   /   /   /\n   /___/___/___/___/\n  /___/___/___/___/\n /___/___/___/___/\n/_/___/___/___/___/\n\nv1.1.0
```

```
=====  
:: Method           : GET  
:: URL              : http://indriver.com  
:: Wordlist          : FUZZ: subdomains-top1million-110000.txt  
:: Header            : Host: FUZZ.indriver.com  
:: Follow redirects  : false  
:: Calibration       : false  
:: Timeout           : 10  
:: Threads           : 40  
:: Matcher           : Response status: 200,204,301,302,307,401,403  
  
=====
```

```
www [Status: 301, Size: 167, Words: 5, Lines: 8]  
S [Status: 301, Size: 167, Words: 5, Lines: 8]  
promo [Status: 301, Size: 167, Words: 5, Lines: 8]  
job [Status: 301, Size: 167, Words: 5, Lines: 8]  
:: Progress: [302/114441] :: Job [1/1] :: 0 req/sec :: Duration: [0:00:00] :: Errors: 0 :: ^C  
quanl@quanl:~/Documents/bmw/lab$
```

Bài 8: Thực hiện scan 1000 port phổ biến trên các danh sách IP tìm được của *.indrivier.com. Báo cáo kết quả tìm được trong file csv.

- Sử dụng câu lệnh nslookup để tìm địa chỉ ip của các tên miền vừa tìm được.

```

quanlène@quanlène: ~/Documents/bmw/lab3$ nslookup www.indriver.com
Server:      127.0.0.53
Address:     127.0.0.53#53

Non-authoritative answer:
www.indriver.com      canonical name = indriver.com.
Name:   indriver.com
Address: 3.162.58.36
Name:   indriver.com
Address: 3.162.58.74
Name:   indriver.com
Address: 3.162.58.44
Name:   indriver.com
Address: 3.162.58.67

quanlène@quanlène: ~/Documents/bmw/lab3$ nslookup s.indriver.com
Server:      127.0.0.53
Address:     127.0.0.53#53

Non-authoritative answer:
Name:   s.indriver.com
Address: 3.162.58.41
Name:   s.indriver.com
Address: 3.162.58.62
Name:   s.indriver.com
Address: 3.162.58.8
Name:   s.indriver.com
Address: 3.162.58.21

quanlène@quanlène: ~/Documents/bmw/lab3$ nslookup promo.indriver.com
Server:      127.0.0.53
Address:     127.0.0.53#53

Non-authoritative answer:

```

```

quanlene@quanlene:~/Documents/bmw/lab3$ nslookup promo.indriver.com
Server:      127.0.0.53
Address:     127.0.0.53#53

Non-authoritative answer:
promo.indriver.com canonical name = d2jiggyp22sfu.cloudfront.net.
Name:   d2jiggyp22sfu.cloudfront.net
Address: 3.162.58.67
Name:   d2jiggyp22sfu.cloudfront.net
Address: 3.162.58.44
Name:   d2jiggyp22sfu.cloudfront.net
Address: 3.162.58.36
Name:   d2jiggyp22sfu.cloudfront.net
Address: 3.162.58.74

quanlene@quanlene:~/Documents/bmw/lab3$ nslookup job.indriver.com
Server:      127.0.0.53
Address:     127.0.0.53#53

Non-authoritative answer:
job.indriver.com canonical name = d2jiggyp22sfu.cloudfront.net.
Name:   d2jiggyp22sfu.cloudfront.net
Address: 3.162.58.74
Name:   d2jiggyp22sfu.cloudfront.net
Address: 3.162.58.36
Name:   d2jiggyp22sfu.cloudfront.net
Address: 3.162.58.67
Name:   d2jiggyp22sfu.cloudfront.net
Address: 3.162.58.44

quanlene@quanlene:~/Documents/bmw/lab3$ nslookup sm.indriver.com
Server:      127.0.0.53
Address:     127.0.0.53#53

```

```

quanlene@quanlene:~/Documents/bmw/lab3$ nslookup spb.indriver.com
Server:      127.0.0.53
Address:     127.0.0.53#53

Non-authoritative answer:
spb.indriver.com canonical name = d2jiggyp22sfu.cloudfront.net.
Name:   d2jiggyp22sfu.cloudfront.net
Address: 3.162.58.44
Name:   d2jiggyp22sfu.cloudfront.net
Address: 3.162.58.36
Name:   d2jiggyp22sfu.cloudfront.net
Address: 3.162.58.67
Name:   d2jiggyp22sfu.cloudfront.net
Address: 3.162.58.74

quanlene@quanlene:~/Documents/bmw/lab3$ nslookup msk.indriver.com
Server:      127.0.0.53
Address:     127.0.0.53#53

Non-authoritative answer:
msk.indriver.com canonical name = d2jiggyp22sfu.cloudfront.net.
Name:   d2jiggyp22sfu.cloudfront.net
Address: 3.162.58.67
Name:   d2jiggyp22sfu.cloudfront.net
Address: 3.162.58.44
Name:   d2jiggyp22sfu.cloudfront.net
Address: 3.162.58.74
Name:   d2jiggyp22sfu.cloudfront.net
Address: 3.162.58.36

quanlene@quanlene:~/Documents/bmw/lab3$ nslookup cargo.indriver.com
Server:      127.0.0.53
Address:     127.0.0.53#53

```

```

quanlene@quanlene:~/Documents/bmw/lab3$ nslookup msk.indriver.com
Server:      127.0.0.53
Address:     127.0.0.53#53

Non-authoritative answer:
msk.indriver.com canonical name = d2jiggyp22sfu.cloudfront.net.
Name:   d2jiggyp22sfu.cloudfront.net
Address: 3.162.58.67
Name:   d2jiggyp22sfu.cloudfront.net
Address: 3.162.58.44
Name:   d2jiggyp22sfu.cloudfront.net
Address: 3.162.58.74
Name:   d2jiggyp22sfu.cloudfront.net
Address: 3.162.58.36

quanlene@quanlene:~/Documents/bmw/lab3$ nslookup cargo.indriver.com
Server:      127.0.0.53
Address:     127.0.0.53#53

Non-authoritative answer:
cargo.indriver.com canonical name = d2jiggyp22sfu.cloudfront.net.
Name:   d2jiggyp22sfu.cloudfront.net
Address: 3.162.58.67
Name:   d2jiggyp22sfu.cloudfront.net
Address: 3.162.58.74
Name:   d2jiggyp22sfu.cloudfront.net
Address: 3.162.58.36
Name:   d2jiggyp22sfu.cloudfront.net
Address: 3.162.58.44

```

- Sử dụng câu lệnh nmap với wordlist top1000port.txt để scan các port phổ biến. Chú ý chỉ scan các địa chỉ ip của tên miền có định dạng xxx.indriver.com

```
quanlene@quanlene:~/Documents/own/lab2$ nmap -p $(cat nmap-ports-top1000.txt | tr '\n' ',') 3.162.58.67 3.162.58.44 3.162.58.36 3.162.58.74 3.162.58.8 3.162.58.62 3.162.58.21 3.162.58.41
Starting Nmap 7.80 ( https://nmap.org ) at 2024-11-20 16:38 +07
WARNING: Duplicate port number(s) specified. Are you alert enough to be using Nmap? Have some coffee or Jolt(tm).
Nmap scan report for server-3-162-58-67.sgn50.r.cloudfront.net (3.162.58.67)
Host is up (0.019s latency).
Not shown: 998 filtered ports
PORT      STATE SERVICE
80/tcp    open  http
443/tcp    open  https

Nmap scan report for server-3-162-58-44.sgn50.r.cloudfront.net (3.162.58.44)
Host is up (0.019s latency).
Not shown: 998 filtered ports
PORT      STATE SERVICE
80/tcp    open  http
443/tcp    open  https

Nmap scan report for server-3-162-58-36.sgn50.r.cloudfront.net (3.162.58.36)
Host is up (0.018s latency).
Not shown: 998 filtered ports
PORT      STATE SERVICE
80/tcp    open  http
443/tcp    open  https

Nmap scan report for server-3-162-58-74.sgn50.r.cloudfront.net (3.162.58.74)
Host is up (0.021s latency).
Not shown: 998 filtered ports
PORT      STATE SERVICE
80/tcp    open  http

PORT      STATE SERVICE
80/tcp    open  http
443/tcp    open  https

Nmap scan report for server-3-162-58-8.sgn50.r.cloudfront.net (3.162.58.8)
Host is up (0.22s latency).
Not shown: 998 filtered ports
PORT      STATE SERVICE
80/tcp    open  http
443/tcp    open  https

Nmap scan report for server-3-162-58-62.sgn50.r.cloudfront.net (3.162.58.62)
Host is up (0.026s latency).
Not shown: 998 filtered ports
PORT      STATE SERVICE
80/tcp    open  http
443/tcp    open  https

Nmap scan report for server-3-162-58-21.sgn50.r.cloudfront.net (3.162.58.21)
Host is up (0.019s latency).
Not shown: 998 filtered ports
PORT      STATE SERVICE
80/tcp    open  http
443/tcp    open  https

Nmap scan report for server-3-162-58-41.sgn50.r.cloudfront.net (3.162.58.41)
Host is up (0.019s latency).
Not shown: 998 filtered ports
PORT      STATE SERVICE
80/tcp    open  http
443/tcp    open  https

Nmap done: 8 IP addresses (8 hosts up) scanned in 379.49 seconds
```

Bài 9: *Xác định phiên bản Apache được sử dụng của tuoitre.uit.edu.vn.*

Dùng lệnh: `curl -IL http://tuoitre.uit.edu.vn`




```
@TanPMT →/workspaces/SecLists (master) $ curl -IL http://tuoitre.uit.edu.vn
HTTP/1.1 302 Found
content-length: 0
location: https://tuoitre.uit.edu.vn/
cache-control: no-cache

HTTP/2 200
date: Fri, 08 Nov 2024 01:48:58 GMT
server: Apache/2.4.57 (CentOS Stream) OpenSSL/3.2.2
x-powered-by: PHP/8.1.29
expires: Sun, 19 Nov 1978 05:00:00 GMT
cache-control: no-cache, must-revalidate
content-language: vi
x-frame-options: SAMEORIGIN
x-content-type-options: nosniff
x-generator: Drupal 7 (https://www.drupal.org)
link: <https://tuoitre.uit.edu.vn/>; rel="canonical",<https://tuoitre.uit.edu.vn/>; rel="shortlink"
content-type: text/html; charset=utf-8
```

Phiên bản apache sử dụng : 2.4.57

Bài 10: CMS nào được sử dụng của trang web tuoitre.uit.edu.vn

Dùng web scanner whatweb để dò

```
@TanPMT →/workspaces/whatweb (master) $ ./whatweb tuoitre.uit.edu.vn
http://tuoitre.uit.edu.vn [302 Found] Country[VIET NAM][VN], IP[118.69.123.140], RedirectLocation[https://tuoitre.uit.edu.vn/]
https://tuoitre.uit.edu.vn/ [200 OK] Apache[2.4.57], Content-Language[vi], Country[VIET NAM][VN], Drupal, Email[vpdoan@uit.edu.vn], HTML5, HTTPServer[CentOS][Apache/2.4.57 (CentOS Stream) OpenSSL/3.2.2], IP[118.69.123.140], MetaGenerator[Drupal 7 (https://www.drupal.org)], OpenSSL[3.2.2], PHP[8.1.29], Script[text/javascript], Title[Tuổi trẻ UIT], UncommonHeaders[x-content-type-options,x-generator,link, X-Frame-Options[SAMEORIGIN], X-Powered-By[PHP/8.1.29]]
```

CMS được sử dụng là: Drupal 7

Sử dụng nmap để dò:

```
@TanPMT →/workspaces/SecLists (master) $ sudo nmap --script=http-enum -p 80,443 tuoitre.uit.edu.vn
Starting Nmap 7.80 ( https://nmap.org ) at 2024-11-08 02:42 UTC
Nmap scan report for tuoitre.uit.edu.vn (45.122.249.78)
Host is up (0.020s latency).
Other addresses for tuoitre.uit.edu.vn (not scanned): 118.69.123.140
rdNS record for 45.122.249.78: static.cmcti.vn

PORT      STATE      SERVICE
80/tcp    filtered  http
443/tcp   open      https
| http-enum:
| /robots.txt: Robots file
| /: Drupal signature
| /UPGRADE.txt: Drupal file
| /INSTALL.txt: Drupal file
| /INSTALL.mysql.txt: Drupal file
| /INSTALL.pgsql.txt: Drupal file
| /CHANGELOG.txt: Drupal v1
| /: Drupal version 7
| /README.txt: Interesting, a readme.
| /0/: Potentially interesting folder
| /icons/: Potentially interesting folder w/ directory listing
|_ /user/: Potentially interesting folder

Nmap done: 1 IP address (1 host up) scanned in 546.66 seconds
```

CMS sử dụng: Drupal version 7

Bài 11: Hệ điều hành và webserver nào được sử dụng của trang web tuoitre.uit.edu.vn.

Dùng lệnh `nmap --script=http-server-header tuoitre.uit.edu.vn` để tìm hệ điều hành và web server

```
# @TanPMT →/workspaces/SecLists (master) $ nmap --script=http-server-header tuoitre.uit.edu.vn
Starting Nmap 7.80 ( https://nmap.org ) at 2024-11-08 01:58 UTC
Nmap scan report for tuoitre.uit.edu.vn (45.122.249.78)
Host is up (0.020s latency).
Other addresses for tuoitre.uit.edu.vn (not scanned): 118.69.123.140
rDNS record for 45.122.249.78: static.cmcti.vn
Not shown: 998 filtered ports
PORT      STATE SERVICE
80/tcp    open  http
443/tcp   open  https
# |_http-server-header: Apache/2.4.57 (CentOS Stream) OpenSSL/3.2.2
```

Web server sử dụng là Apache HTTP Server 2.4.57

Hệ điều hành sử dụng là : CentOS Stream

Bài 12: Sử dụng <https://web.archive.org/> tìm kiếm và ghi nhận lại dữ liệu quá khứ các tên miền phụ không còn tồn tại hiện nay của terra-1.indriverapp.com. File <https://terra-1.indriverapp.com/robots.txt> có chứa nội dung gì

Tìm kiếm và ghi nhận lại dữ liệu quá khứ các tên miền phụ không còn tồn tại:

32 URLs have been captured for this URL prefix.

Filter results by URL or MIME Type (i.e. '.txt')

URL ↑	MIME Type	From	To	Captures	Duplicates	Uniques
https://terra-1.indriverapp.com/	text/html	May 17, 2022	Mar 20, 2024	3	0	3
https://terra-1.indriverapp.com/api/authorization	application/octet-stream	Apr 5, 2023	Apr 5, 2023	1	0	1
https://terra-1.indriverapp.com/api/authorization?locale=ru	application/octet-stream	Apr 3, 2023	Apr 3, 2023	1	0	1
https://terra-1.indriverapp.com/content/46550938ef802eab1952edc6dea015d6ffc38a40-15f50fb68f8fab27307.js	application/javascript	May 17, 2022	May 17, 2022	1	0	1
https://terra-1.indriverapp.com/content/77139f25b80580223d87f80cdf53082072b7343e-caac4a7203bda6bf8efc.js	application/javascript	Apr 3, 2023	Apr 3, 2023	1	0	1
https://terra-1.indriverapp.com/content/881d1825384a5b2d8a0199480384f5f537c5e641-9cf95b54dc679511b832.js	application/javascript	May 17, 2022	May 17, 2022	1	0	1
https://terra-1.indriverapp.com/content/app-362b2d7b31ad7e48116a.js	application/javascript	Apr 3, 2023	Apr 3, 2023	1	0	1
https://terra-1.indriverapp.com/content/app-49d8abe3c15e5543411e.js	application/javascript	May 17, 2022	May 17, 2022	1	0	1
https://terra-1.indriverapp.com/content/component---src-pages-index-tsx-2b4a263c6d5d3d1910ad.js	application/javascript	Apr 3, 2023	Apr 3, 2023	1	0	1
https://terra-1.indriverapp.com/content/component---src-pages-index-tsx-4c83949204b25b17f3e7.js	application/javascript	May 17, 2022	May 17, 2022	1	0	1
https://terra-1.indriverapp.com/content/fc2a6c1544feec221c7cd807d4107d2706e29583-d6949b10a456ca707f7c.js	application/javascript	Apr 4, 2023	Apr 4, 2023	1	0	1

Nội dung của file <https://terra-1.indriverapp.com/robots.txt>:

INTERNET ARCHIVE
Wayback Machine

Explore more than 916 billion web pages saved over time

<https://terra-1.indriverapp.com>

Calendar · Collections · Changes · Summary · Site Map · **URLs**

32 URLs have been captured for this URL prefix.

robots.txt

URL ↑	MIME Type	From	To	Captures	Duplicates	Uniques
https://terra-1.indriverapp.com/robots.txt	text/plain	Nov 2, 2019	Apr 3, 2023	9	6	3

Showing 1 to 1 of 1 entries (filtered from 32 total entries)

First Previous **1** Next Last

[FAQ](#) | [Contact Us](#) | [Terms of Service](#) (Dec 31, 2014)

Theo kết quả tìm kiếm trên Internet, file robots.txt là tệp văn bản trong thư mục gốc của trang web, dùng để hướng dẫn bot công cụ tìm kiếm (web crawler) về các khu vực được phép hoặc không được phép thu thập dữ liệu. Nó chứa các chỉ thị như Useragent (bot áp dụng), Disallow (chặn truy cập), và Sitemap (đường dẫn sơ đồ trang web). Tuy nhiên, robots.txt không bảo mật và chỉ là một hướng dẫn cho bo

Bài 13: *Tìm kiếm các tập tin pdf, excel, word, trên *.indriver.com.*

Ta dùng lệnh sau trong Github search để tìm:
filename:*.doc OR filename:*.docx "indriver.com"

Kết quả trả về như sau:

github.com/search?q=filename%3A*.doc+OR+filename%3A*.docx+"indriver.com"&type=repositories

filename:*.doc OR filename:*.docx "indriver.com"

Filter by

- <> Code 0
- Repositories 16**
- Issues 0
- Pull requests 1
- Discussions 0
- Users 0
- Commits 25
- Packages 0
- Wikis 0
- Topics 0
- Marketplace 0

Advanced

- Owner
- Size
- Number of followers
- Number of forks
- Number of stars
- Date created
- Date pushed

16 results (198 ms)

Sort by: Best match Save

- [dream-PsP/truck.indriverapp.com](#)
☆ 1 · Updated on 25 thg 2, 2023
- [cyber-lacoco/share.indriver.com](#)
☆ 0 · Updated on 6 thg 3, 2023
- [dream-PsP/market.indriverapp.com](#)
☆ 0 · Updated on 18 thg 2, 2023
- [dream-PsP/watchdocs.indriverapp.com](#)
☆ 0 · Updated on 18 thg 2, 2023
- [dream-PsP/classified.indriver.com](#)
☆ 0 · Updated on 18 thg 2, 2023
- [venom1312/super-services.indriverapp.com](#)
HTML · ☆ 0 · Updated on 8 thg 1

Sponsor open source projects you depend on

Contributors are working behind the scenes to make open source better for everyone—give them the help and recognition they deserve.

[Explore sponsorable projects](#)

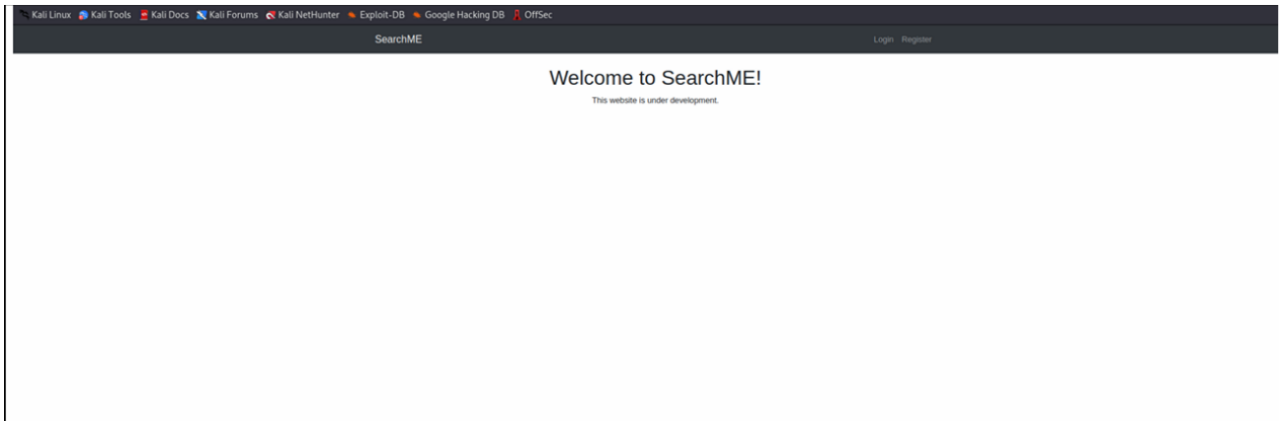
How can we improve search? [Give feedback](#)

ProTip! Press the `/` key to activate the search input again and adjust your query.

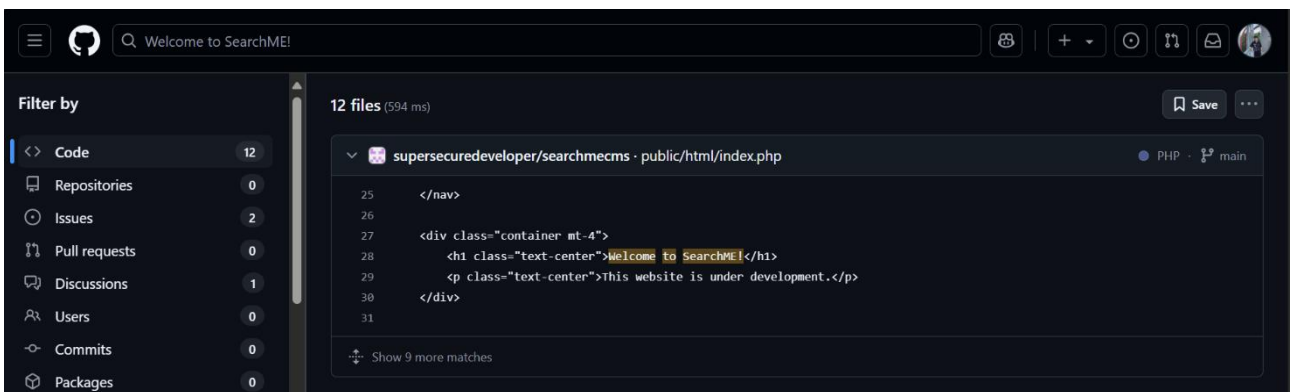
Lab 2: Tổng quan các lỗ hổng web thường gặp (P2)

Bài 14: Chúng tôi có 1 trang web đang trong quá trình phát triển, hãy tìm thử API key cho phép user tạo tài khoản trên website này.

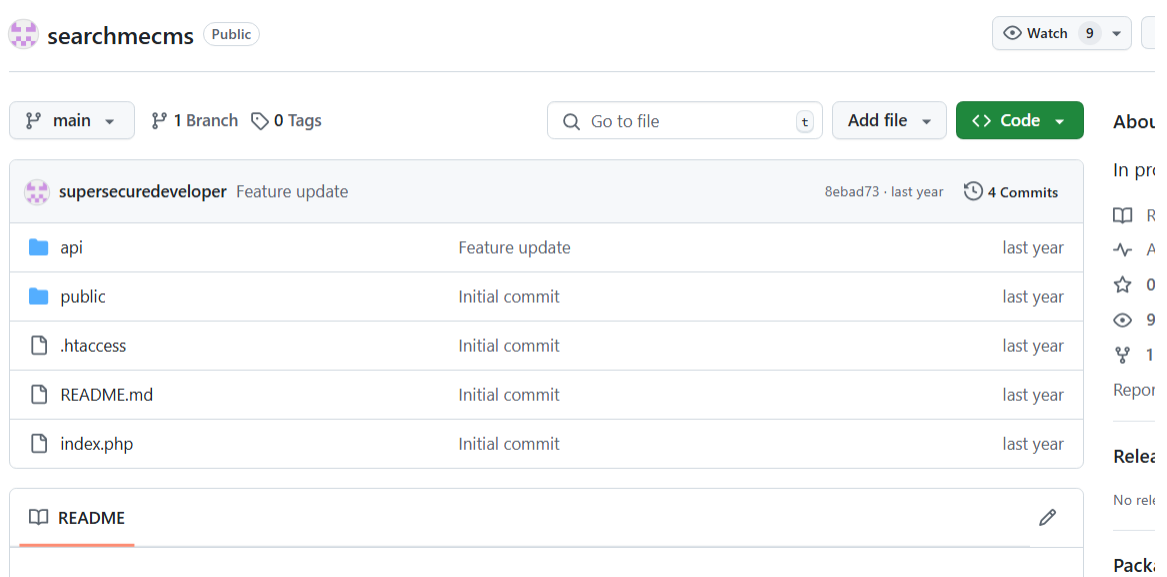
- Ta sử dụng Github search để tìm api key cho phép tạo user của trang web này:



- Dùng Github search để tìm những đoạn code hiển thị “Welcome to SearchME!”:



- Nhận thấy những điểm tương tự, ta vào repo của user supersecurededeveloper để kiểm tra:



Lab 2: Tổng quan các lỗi hỏng web thường gặp (P2)

- Kiểm tra lịch sử commit, ta thấy có 1 commit “Fix: remove key”.

Commits on May 25, 2023	
Fix: remove key  supersecuredeveloper committed on May 25, 2023	db11421  <>
Initial commit  supersecuredeveloper committed on May 25, 2023	ccff6f8  <>

- Truy cập để xem nội dung commit, ta thấy API key bị lộ:

1 file changed +1 -1 lines changed

api/register.php

@@ -4,7 +4,7 @@

4 4

5 5 \$headers = apache_request_headers();

6 6

7 - if (isset(\$headers['X-THM-API-Key']) && \$headers['X-THM-API-Key'] === 'ffe60ecaa8bba2f12b43d1a4b15b8f39') {

7 + if (isset(\$headers['X-THM-API-Key']) && \$headers['X-THM-API-Key'] === 'TBA') {

8 8 \$input = json_decode(file_get_contents('php://input'), true);

9 9

10 10 \$stmt = \$mysqli->prepare("INSERT INTO users (username, password, email, name) VALUES (?, ?, ?, ?)");

Custom

The def

accessil

line hei

En

Bài 15: *Viết code crawling trang web <https://indriver.com> để lấy các thông tin liên quan như list email, các đường dẫn liên kết (links), danh sách js, images, comment.*

- Crawling trang web <https://indriver.com>
- Sử dụng request và BeautifulSoup(bs4)

```
import requests
from bs4 import BeautifulSoup, Comment
import re

# URL of the website to crawl
url = 'https://indriver.com'

response = requests.get(url)
html_content = response.text

soup = BeautifulSoup(html_content, 'html.parser')

# Function to find emails using regex
Tabnine | Edit | Test | Explain | Document | Ask
def find_emails(text):
    email_pattern = r'[a-zA-Z0-9._%+-]+@[a-zA-Z0-9.-]+\.[a-zA-Z]{2,}'
    return re.findall(email_pattern, text)

# Extract emails
emails = find_emails(html_content)

# Extract all links
links = [a['href'] for a in soup.find_all('a', href=True)]

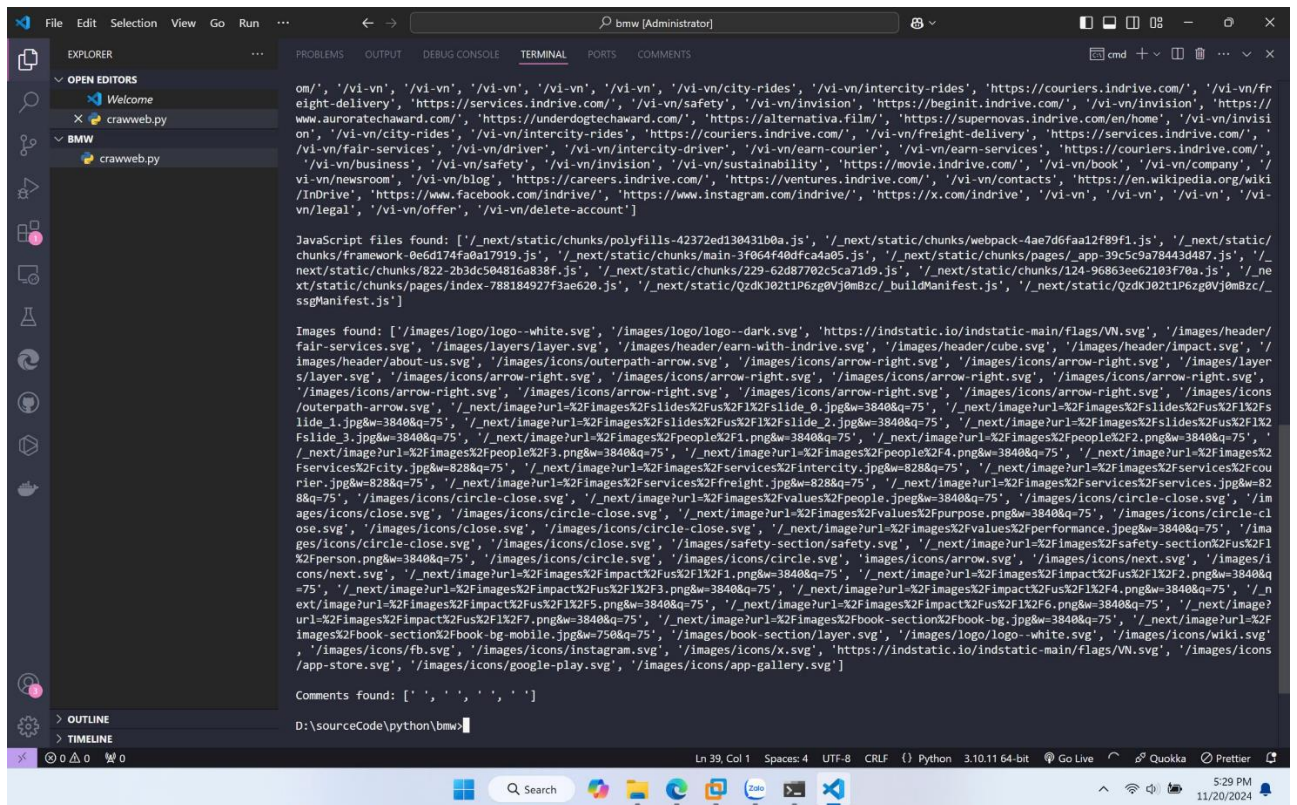
# Extract JavaScript files
scripts = [script['src'] for script in soup.find_all('script', src=True)]

# Extract images
images = [img['src'] for img in soup.find_all('img', src=True)]

# Extract comments from HTML
comments = soup.find_all(string=lambda text: isinstance(text, Comment))

# Print results
print("Emails found:", emails)
print("\nLinks found:", links)
print("\nJavaScript files found:", scripts)
print("\nImages found:", images)
print("\nComments found:", comments)
```

- Sau khi crawl ta được các thông tin liên quan như : list emails, links, scripts, images và comments

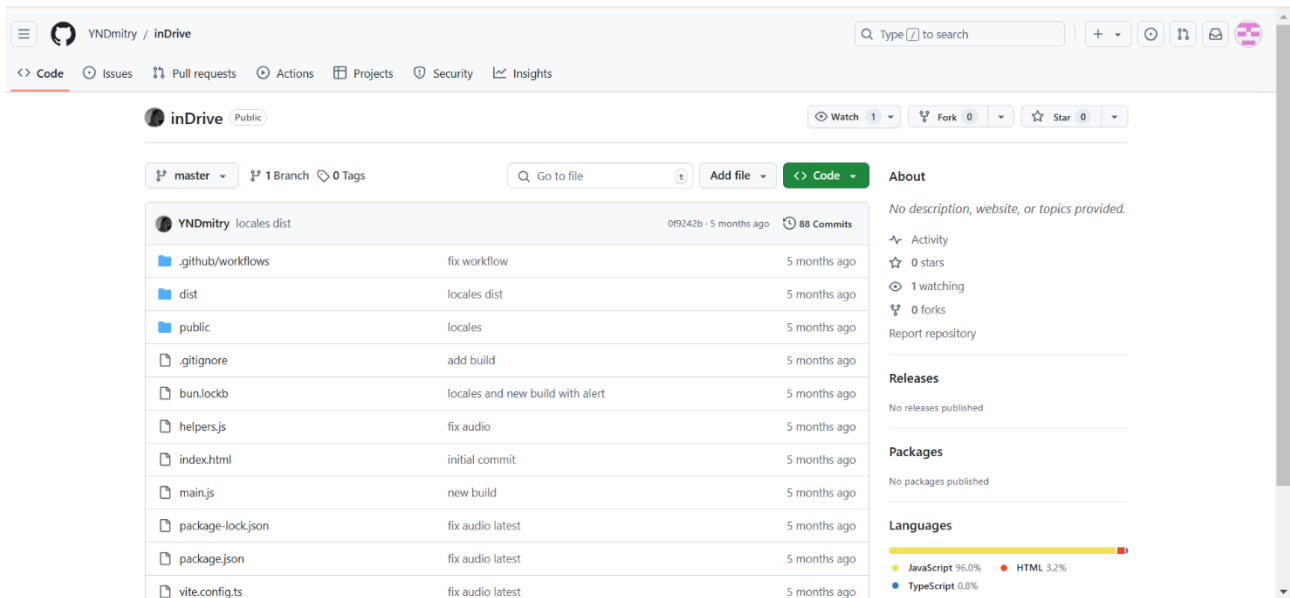


PHẦN II: BÀI TẬP THỰC HÀNH

Which sites did YNDmitry develop on inDrive.com?

- YDNmitry là người phát triển phiên bản đầu tiên của app inDrive, bao gồm nền tảng IOS và Android

<https://github.com/YNDmitry/inDrive>



Trang web tại địa chỉ 103.77.240.59:

- Dựa vào ký tự đầu tiên bị lộ (tô đỏ), ta đoán là “z” => brute force 4 ký tự còn lại với độ phức tạp là 26^4
- Ta dùng python để bruteforce:


```
import itertools
import requests

# Địa chỉ base domain
base_domain = "studywithme.info"

# Tạo các tổ hợp subdomain từ tiền tố đã biết
Tabnine | Edit | Test | Explain | Document | Ask
def generate_subdomains(prefix="z865", length=4):
    chars = "abcdefghijklmnopqrstuvwxyz"
    for combination in itertools.product(chars, repeat=length):
        yield f"{prefix}{'.'.join(combination)}" # Ghép tiền tố với tổ hợp mới

# Kiểm tra subdomain
Tabnine | Edit | Test | Explain | Document | Ask
def check_subdomain(subdomain):
    url = f"http://{subdomain}.{base_domain}"
    try:
        response = requests.get(url, timeout=5)
        if response.status_code == 200:
            print(f"[FOUND] Subdomain: {url}")
            return url
    except requests.exceptions.RequestException:
        pass # Bỏ qua lỗi kết nối
    return None

# Hàm chính
Tabnine | Edit | Test | Explain | Document | Ask
def main():
    print("Starting subdomain scan with prefix 'z86g5y'...")
    for sub in generate_subdomains(): # Tạo các tổ hợp dựa trên tiền tố z86g5y
        result = check_subdomain(sub)
        if result:
            # Ghi lại subdomain tìm được
            with open("found_subdomains.txt", "a") as f:
                f.write(result + "\n")
            break # Dừng lại nếu tìm thấy subdomain hợp lệ

if __name__ == "__main__":
```

- Ta thu được kết quả:

```

(kali@kali)-[~/Documents/Lab3]
$ curl -H "Host: baomatweb-z86g5ycw.studywithme.info" http://103.77.240.59
congratulation you find how vhosts works!!!<br>now you need FUZZ to find secret file!!!

(kali@kali)-[~/Documents/Lab3]
$
15619 baomatweb-z86g5ycw.studywithme.info not found.
15620 baomatweb-z86g5ycw.studywithme.info here
15621 baomatweb-z86g5ycw.studywithme.info not found.
15622 baomatweb-z86g5ycw.studywithme.info not found.
15623 baomatweb-z86g5ycw.studywithme.info not found.
15624 baomatweb-z86g5ycw.studywithme.info not found.
15625 baomatweb-z86g5ycw.studywithme.info not found.
15626 baomatweb-z86g5ycw.studywithme.info not found.
15627 baomatweb-z86g5ycw.studywithme.info not found.
15628 baomatweb-z86g5ycw.studywithme.info not found.

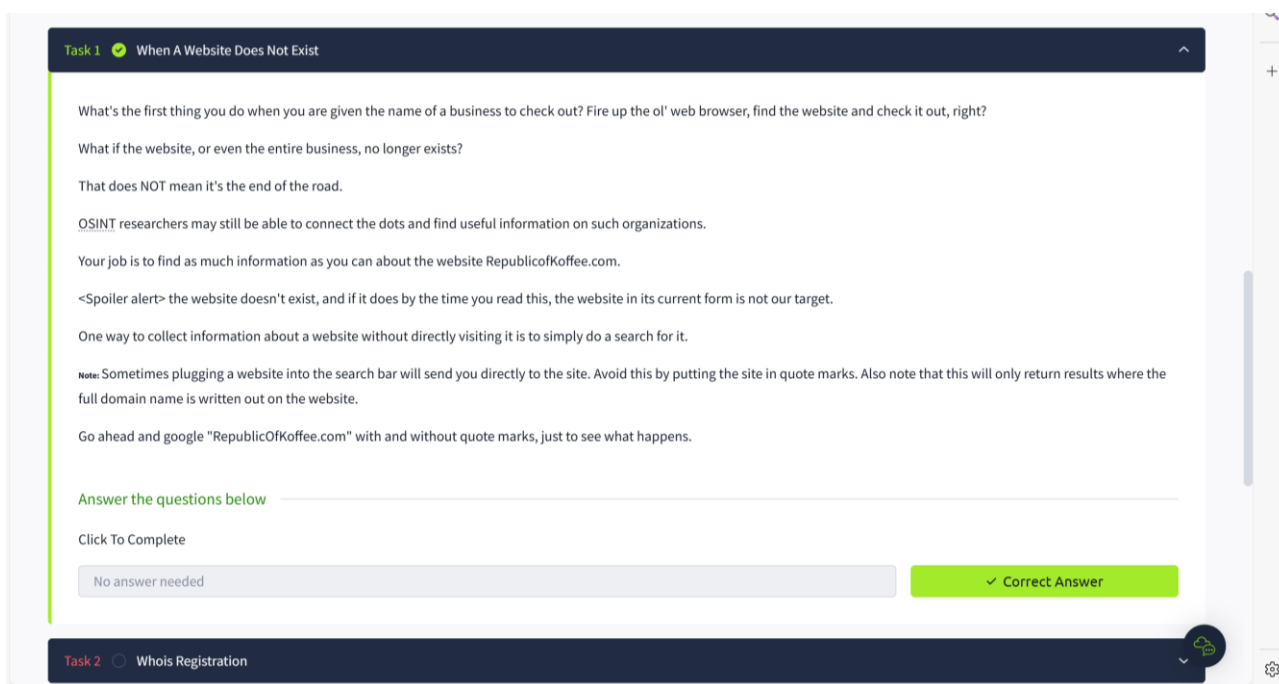
```

- Với kết quả là: “z86g5ycw” => ta sẽ tìm được tên miền.

Tryhackme – WebOSINT - <https://tryhackme.com/r/room/webosint>

Task 1: When A Website Does Not Exist

- Để muốn ta tìm hiểu càng nhiều thông tin càng tốt về website RepublicofKoffee.com. Tuy nhiên website đó không tồn tại, nhưng không tồn tại thì không có nghĩa là ta không tìm hiểu được.
- Ta thử truy cập vào thì được như ảnh dưới, và bấm hoàn thành:



- Chỉ là 1 trang web bình thường, cùng làm câu tiếp theo.

Task 2: Whois Registration

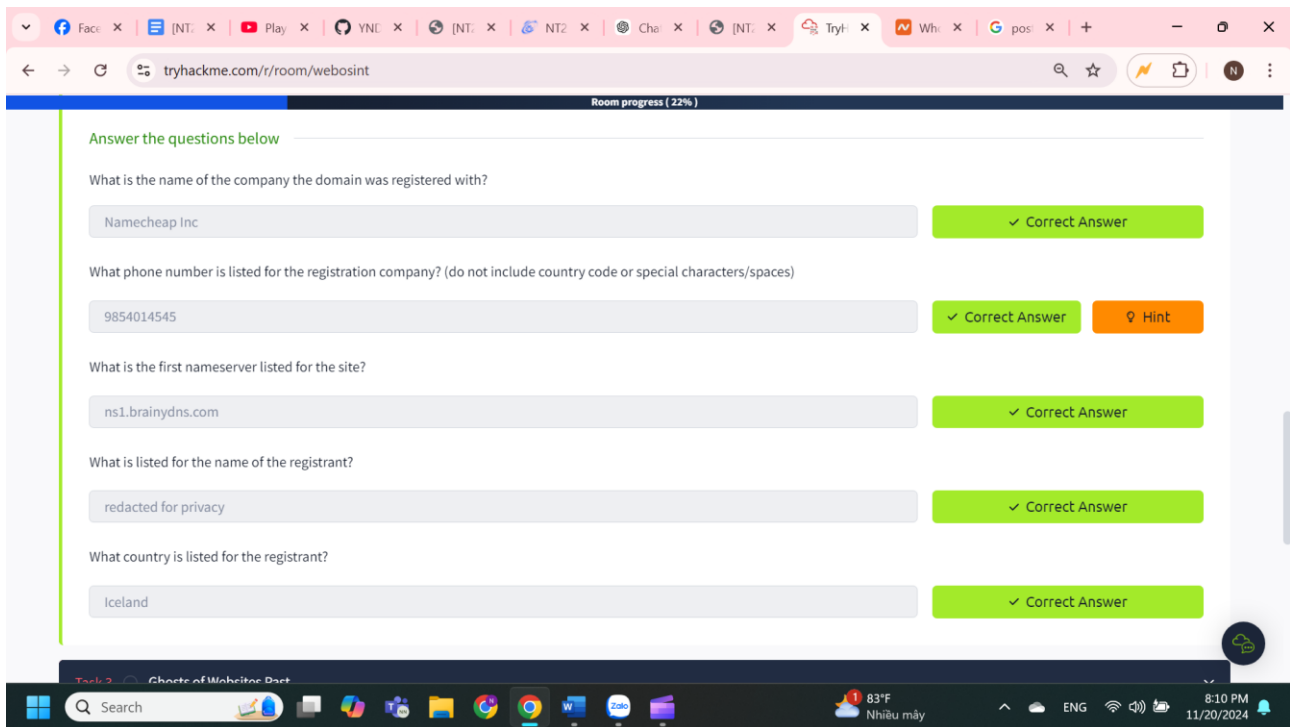
- Đề hỏi các câu như sau và để làm được các câu này, ta dùng tool Namecheap WHOIS Tool được đề gợi ý:
 - What is the name of the company the domain was registered with?
 - NAMECHEAP INC (ở trường Reseller)
 - What phone number is listed for the registration company? (do not include country code or special characters/spaces)
 - 9854014545 (ở trường Registrar Abuse Contact Phone)
 - What is the first nameserver listed for the site?
 - ns1.brainydns.com (ở trường Name Server)
 - What is listed for the name of the registrant?
 - Redacted for privacy (ở trường Registrant Name)
 - What country is listed for the registrant?
 - Iceland (từ thành phố Reyjavik, ta suy ra được đây là ở Iceland)
- Đây là nội dung sau khi ta dùng tool được gợi ý và từ những trường thông tin ở đó, ta có thể trả lời được những câu hỏi ở trên:

Whois results: republicofkoffee.com is available. Want it? Register now.

republicofkoffee.com PREMIUM ⓘ

Make offer

Domain name: RepublicOfKoffee.com
Registry Domain ID: 2582024072_DOMAIN_COM-VRSN
Registrar WHOIS Server: whois.namecheap.com
Registrar URL: http://www.namecheap.com
Updated Date: 2024-01-11T02:08:15.56Z
Creation Date: 2021-01-01T17:33:07.00Z
Registrar Registration Expiration Date: 2025-01-01T17:33:07.00Z
Registrar: NAMECHEAP INC
Registrar IANA ID: 1068
Registrar Abuse Contact Email: abuse@namecheap.com
Registrar Abuse Contact Phone: +1.9854014545
Reseller: NAMECHEAP INC
Domain Status: clientTransferProhibited https://icann.org/epp#clientTransferProhibited
Registry Registrant ID:
Registrant Name: Redacted for Privacy
Registrant Organization: Privacy service provided by Withheld for Privacy ehf
Registrant Street: Kalkofnsvegur 2
Registrant City: Reykjavik
Registrant State/Province: Capital Region
Registrant Postal Code: 101
Registrant Country: IS
Registrant Phone: +354.4212434



Task 3: Ghosts of Websites Past

- Đề hỏi các câu hỏi như sau và gợi ý ta dùng Wayback Machine - công cụ để xem 1 trang web trong quá khứ trông như thế nào:
 - o What is the first name of the blog's author?

CAFFE BONITO; MUDEUNGSAN

🕒 June 24, 2015 👤 Steve

On occasion I find myself having meetings in the Mudeungsan national park area of Gwangju. On these occasions, I typically set the meeting place as the Starbucks there. It has a small dedicated parking area and several floors of seating, including the rooftop, with gorgeous views of the surrounding area.

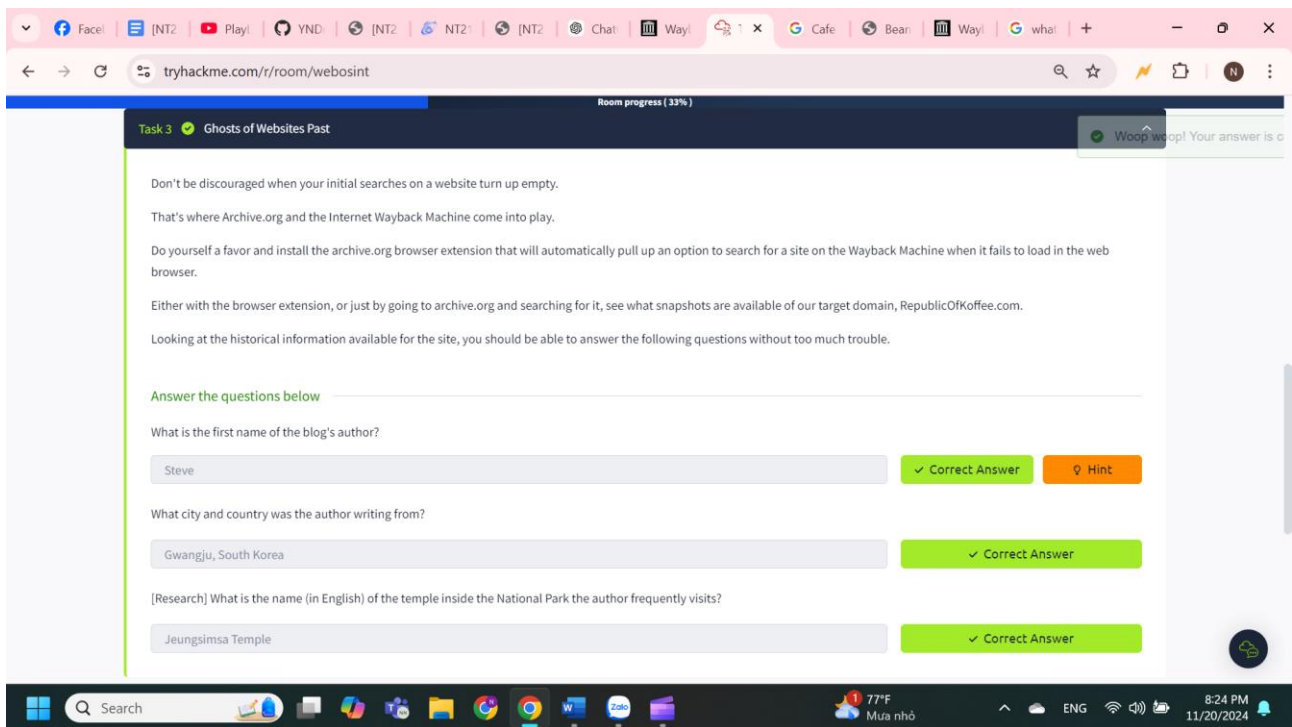
The small parking lot sometimes gets rather full, however, and one day I found it impossible to go there. I did a couple U-turns and ended up at the Caffe Bonito

- Ở đây ta thấy tên chủ blog là Steve(ở các post khác cũng vậy) nên do đó câu trả lời của câu này sẽ là Steve. Ngoài ra tác giả đề cập rằng anh ta hay đi công viên quốc gia Mudeungsan nên từ đó ta cũng trả lời được câu 2 là hiện anh ta đang ở

Lab 2: Tổng quan các lỗi hỏng web thường gặp (P2)

Gwangju,, Hàn Quốc Từ đó ta cũng có thể tìm các ngôi đền ở trong công viên này để trả lời câu 3.

- Steve
 - What city and country was the author writing from?
 - Gwangju, South Korea
 - [Research] What is the name (in English) of the temple inside the National Park the author frequently visits?
 - Jeungsimsa Temple
- Sau khi trả lời xong, ta được như sau:



Task 4: Digging into DNS

- Đề hỏi ta các câu như sau, và gợi ý dùng tool viewdns.info để làm:
 - What was RepublicOfKoffee.com's IP address as of October 2016?
 - 173.248.188.152
- Ta dùng tính năng IP history của trang web để tìm được như sau:

Lab 2: Tổng quan các lỗi hồng web thường gặp (P2)

185.107.56.55	Roosendaal - The Netherlands	NForce Entertainment B.V.	2022-02-24
185.107.56.193	The Netherlands	NForce Entertainment B.V.	2022-02-24
162.210.199.87	Manassas - United States	LEASEWEB-USA-WDC	2022-02-24
74.63.241.24	Dallas - United States	LIMESTONENETWORKS	2022-02-23
185.107.56.53	Roosendaal - The Netherlands	NForce Entertainment B.V.	2022-02-23
96.47.230.67	Miami - United States	ASN-QUADRANET-GLOBAL	2022-02-22
82.192.82.228	The Netherlands	LeaseWeb Netherlands B.V.	2022-02-22
74.63.241.27	Dallas - United States	LIMESTONENETWORKS	2022-02-22
74.63.241.27	Dallas - United States	LIMESTONENETWORKS	2022-02-22
192.157.56.142	Buffalo - United States	SERVER-MANIA	2022-02-22
185.107.56.54	Roosendaal - The Netherlands	NForce Entertainment B.V.	2022-02-22
162.210.199.65	Manassas - United States	LEASEWEB-USA-WDC	2022-02-22
162.210.199.65	Manassas - United States	LEASEWEB-USA-WDC	2022-02-22
99.83.154.118	United States	AMAZON-02	2022-02-09
192.64.119.238	United States	NAMECHEAP-NET	2022-01-01
69.64.147.10	United States	RIGHTSIDE	2017-07-30
173.248.188.152	United States	WEHOSTWEBSITES-COM	2016-10-03
173.248.187.2	United States	WEHOSTWEBSITES-COM	2016-02-01

- Based on the other domains hosted on the same IP address, what kind of hosting service can we safely assume our target uses?
- Ở đây câu hỏi khá khó hiểu nên ta sẽ xem hint như sau:
 - What kind of hosting plan is usually used by websites on a tight budget that don't have a lot of visitors?"
- Từ hint trên ta có thể dùng Reverse IP và có kết quả:

[ViewDNS.info](#) > [Tools](#) > **Reverse IP Lookup**

Takes a domain or IP address and does a reverse lookup to quickly shows all other domains hosted from the same server. Useful for finding phishing sites or identifying other sites on the same shared hosting server.

■ Shared

- Từ đó có thể nhận ra rằng đây là Shared web hosting - là một dịch vụ lưu trữ web mà trong đó nhiều website khác nhau cùng chia sẻ tài nguyên của một máy chủ vật lý duy nhất.

Task 4 Digging into DNS

So far we've gathered some good info about the content that was on our target website, even though it hasn't been live for several years.

But what about technical details?

That's where ViewDNS.info comes in.

ViewDNS.info provides a convenient UI for looking up registration information on a target website. Using this information, it may be possible to draw certain conclusions that are not clearly spelled out, such as whether the website is hosted on a shared or dedicated IP address. The answer to this question can imply things about the website's budget as well as traffic.

Take a look at the search options available and see if you can answer these questions.

Answer the questions below

What was RepublicOfKoffee.com's IP address as of October 2016?

✓ Correct Answer

🔍 Hint

Based on the other domains hosted on the same IP address, what kind of hosting service can we safely assume our target uses?

✓ Correct Answer

🔍 Hint

Task 5: Taking Off The Training Wheels

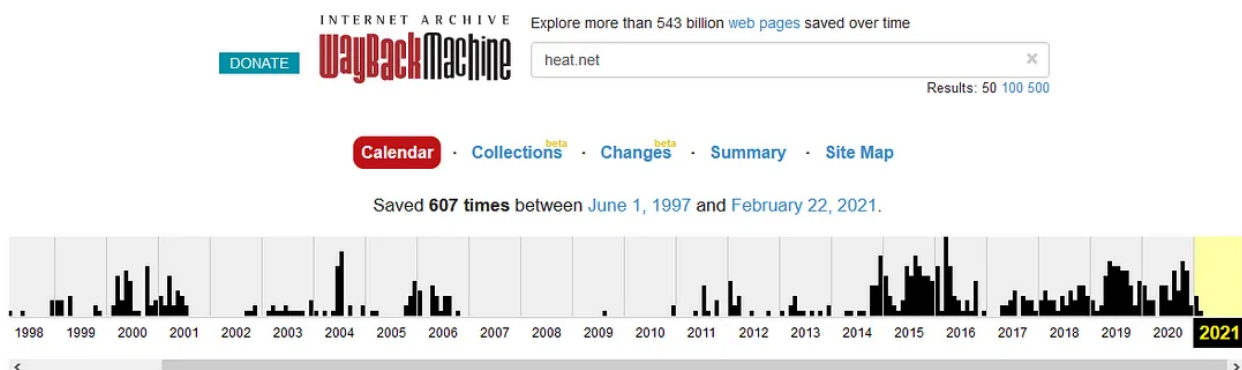
- Lần này ta bắt đầu với 1 tên miền hoàn toàn mới và dùng những kiến thức ở trên để giải quyết những câu hỏi ở đây:
 - What is the second nameserver listed for the domain?
- Ta dùng tool whois ở trên để giải quyết câu này và xem ở trường nameserver
 - NS2.HEAT.NET
 - What IP address was the domain listed on as of December 2011?
- Ở đây ta dùng tính năng IP History được chỉ ở trên để làm
 - 72.52.192.240
 - Based on domains that share the same IP, what kind of hosting service is the domain owner using?
 - shared
- Dùng tính năng Reverse IP, ta thấy còn có nhiều trang web khác sử dụng chung với địa chỉ IP này, từ đó có thể thấy rằng đây là Shared web hosting như trang trên

Reverse IP results for 208.117.87.195
=====

There are 48 domains hosted on this server.
The complete listing of these is below:

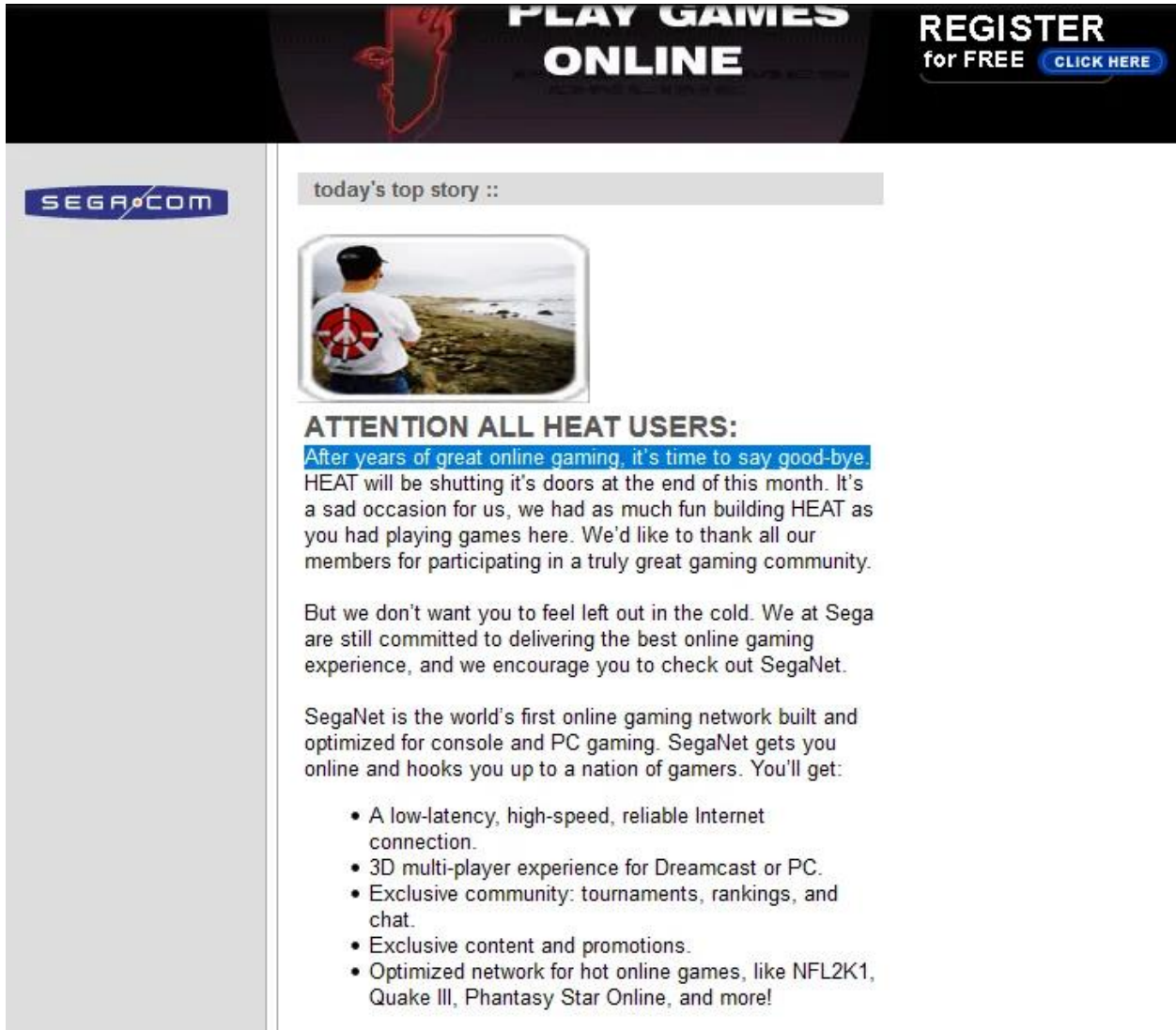
Domain	Last Resolved Date
acefest.com	2021-02-17
addonplanet.com	2021-02-25
astronomy-pictures.net	2021-02-22
blackberryfaq.com	2021-02-17
blackberryforums.com	2021-02-25
canon-30d.com	2021-02-17
ccmostwanted.com	2021-02-25
collectorcarsforsale.com	2021-02-25
creativenoise.net	2021-02-22
dragcars.com	2021-02-25
egyptartsite.com	2021-02-25
electronic-circuits-diagrams.com	2021-02-25
fast-autos.net	2021-02-25
ffcompendium.com	2021-02-25
fleetwoodmac.net	2021-02-25
fsdownload.com	2021-02-25
fsplanet.com	2021-02-25
golfclubsreview.org	2021-02-20
gorillabaseball.com	2021-02-17
heat.net	2021-02-26
homerweb.com	2021-02-25
hydroponicsonline.com	2021-02-25
jdmmdirectory.com	2021-02-17

- On what date was the site first captured by the internet archive?
(MM/DD/YY format)
 - 06/01/97
- Dùng wayback machine, ta thấy record đầu tiên về web này là vào ngày 1 tháng 6 năm 1997.

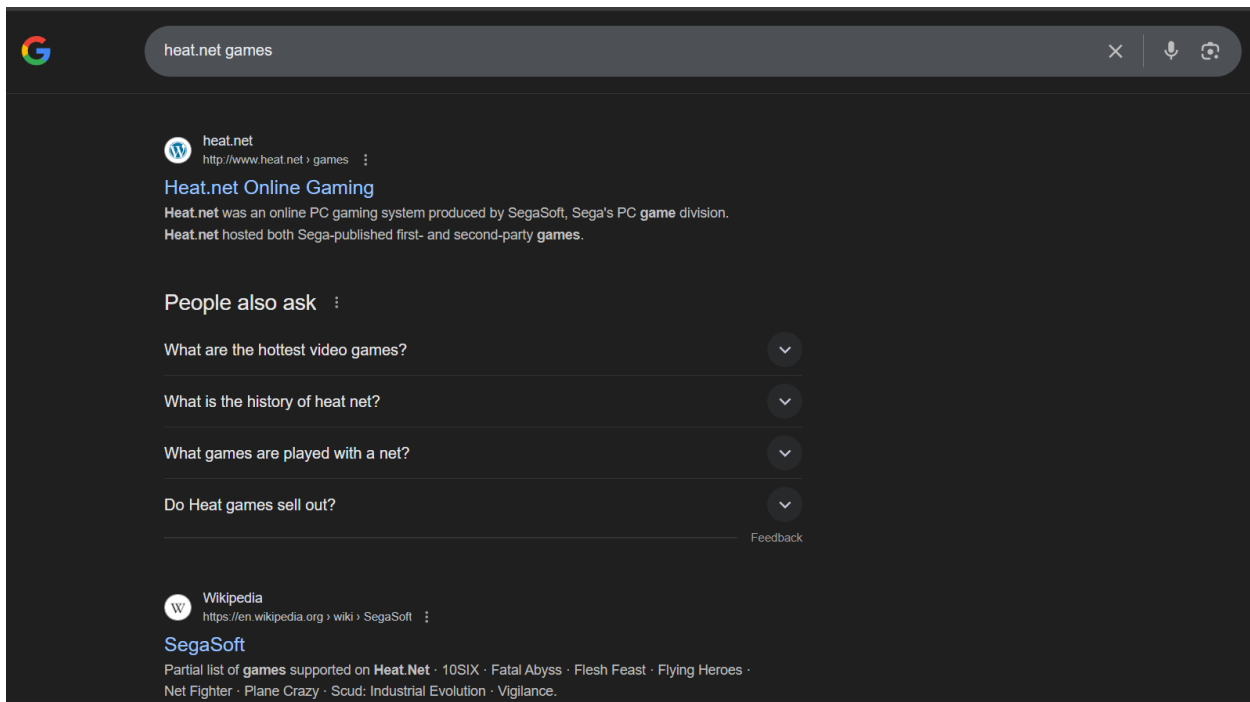


Lab 2: Tổng quan các lỗi hỏng web thường gặp (P2)

- What is the first sentence of the first body paragraph from the final capture of 2001?
- Ta dùng wayback machine để xem lần cuối cùng trang web được chụp lại vào năm 2001 và thấy được trang như này:



- After years of great online gaming, it's time to say good-bye
- Using your search engine skills, what was the name of the company that was responsible for the original version of the site?



- SegaSoft
 - What does the first header on the site on the last capture of 2010 say?
- Heat.net - Heating and Cooling

Heat.net



Heating and Cooling, HVAC, Residential & Commercial Heat

RATED #1 - Heating and Cooling (Nationwide)

Don't Get Left in the Cold!

Get 3 Furnace Estimates Now!

Free Estimates - Next 48 Hours

QualitySmith

CLICK HERE

Heat.net – Heating and Cooling

No matter how you think about it, a house is simply not a home without proper functioning **heating and cooling** systems and devices. And the same can be said about any business or commercial property.

Think about it for a moment. Is it any use having a nice house to provide shelter if you end up shivering and shivering all through the night on those long, cold winter nights or dripping in sweat all summer long? Or having an office space that you dread heading to every day?

Whether you are looking to purchase a new home or commercial space, or simply want to make the most of the one you have, heating and cooling systems are often the most important factor of real estate ownership on the whole.

BBB

CERTIFIED

AC & HEATING

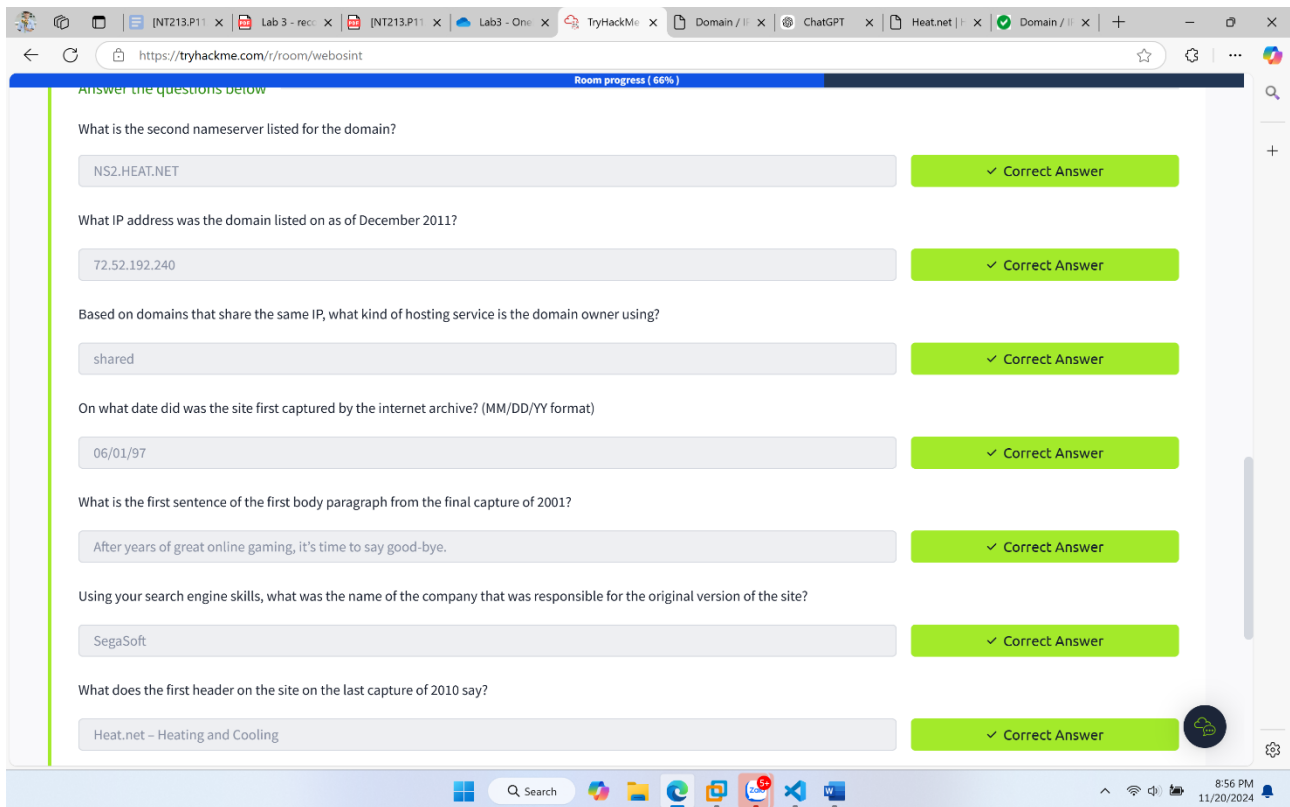
In-Online... Call Confirmed!

Find A Top Rated Handyman



Get 4 Quotes
and find the right handyman

It's totally free...



Task 6: Taking A Peek Under The Hood Of A Website

- Đề yêu cầu ta tìm thêm các thông tin của trang web này qua các câu hỏi như bên dưới:
 - How many internal links are in the text of the article?
- Ta đến trang web hiện tại, <http://www.heat.net/> và có thể biết những trang nội bộ bằng cách di chuột qua liên kết và xác minh xem nó sẽ đưa đến đâu. Nếu nó đưa bạn đến một trang heat.net khác, thì đó là trang nội bộ.
 - 5
 - How many external links are in the text of the article?
- Ngược lại với cái ở trên, ta xem nếu link đó dẫn ra trang khác thì là link external
 - 1
 - Website in the article's only external link (that isn't an ad)
- Nhấn vào link external trên, ta có như sau:



- Purchase.org
 - o Try to find the Google Analytics code linked to the site
- Ta f12 tìm code trong source và có như sau:
 - UA-251372-24

```

}
</style>
<link rel='stylesheet' id='wp-block-library-css' href='http:
<link rel='https://api.w.org/' href='http://www.heat.net/wp-json/
<link rel="EditURI" type="application/rsd+xml" title="RSD" href="
<link rel="wlwmanifest" type="application/wlwmanifest+xml" href="
<meta name="generator" content="WordPress 5.4.4" />
<link rel='shortlink' href='http://www.heat.net/?p=36' />
<link rel="alternate" type="application/json+oembed" href="http://
<link rel="alternate" type="text/xml+oembed" href="http://www.hea
<link rel="stylesheet" type="text/css" media="screen" href="http:

<script type="text/javascript">
window.google_analytics_uacct = "UA-251372-24";
</script>
    
```

- o Is the the Google Analytics code in use on another website? Yay or nay
- Ta dùng <https://www.nerdydata.com/> để thực hiện nhiệm vụ này:

Technology Explorer

← EDIT SEARCH 1 Website Found DOWNLOAD WEBSITE LIST

Websites with all of these: And, any of these: And, none of these:

us-251372-24

Websites using ua-251372-24

Domain	Alexa Rank	Tech Spend	Emails	Country	Industry	Company	LinkedIn	Facebook	Instagram	Twitter
heat.net	3.2K	\$10K - \$30K	..	..	..	..	..	..	..	..

Want more results? [Click Here](#) and register for a free account

Lab 2: Tổng quan các lỗ hổng web thường gặp (P2)

- Nay
 - Does the link to this website have any obvious affiliate codes embedded with it? Yay or Nay
- Ta có thể biết một liên kết có mã liên kết hay không bằng cách nhìn vào nó. Nếu bạn di chuột qua nó và nó chỉ dẫn bạn đến 'www.purchase.org' thì không, không có mã liên kết nào được đính kèm vào đó. Nhưng nếu bạn thấy một loạt thông tin bổ sung, thì đó có thể là một liên kết liên kết.
- Nay

Room progress (88%)

Answer the questions below

How many internal links are in the text of the article?

5 ✓ Correct Answer Hint

How many external links are in the text of the article?

1 ✓ Correct Answer Hint

Website in the article's only external link (that isn't an ad)

purchase.org ✓ Correct Answer

Try to find the Google Analytics code linked to the site

UA-251372-24 ✓ Correct Answer

Is the the Google Analytics code in use on another website? Yay or nay

nay ✓ Correct Answer Hint

Does the link to this website have any obvious affiliate codes embedded with it? Yay or Nay

Nay ✓ Correct Answer Hint

Task 7: Final Exam: Connect the Dots

- Use the tools in Task 4 to confirm the link between the two sites. Try hard to figure it out without the hint.
- Ta dùng tool IP History để xem rằng có mối liên kết gì không và ta có thể nhận ra rằng chúng đều được host bởi Liquid Web, L.L.C

[ViewDNS.info](#) > [Tools](#) > **IP History**

Shows a historical list of IP addresses a given domain name has been hosted on as well as where that IP address is geographically located, and the owner of that IP address.

Domain (e.g. domain.com):

GO

IP history results for heat.net.
=====

IP Address	Location	IP Address Owner	Last seen on this IP
208.117.87.195	Reston - United States	Atlantic.Net - Ashburn, VA	2021-02-27
74.116.2.147	United States	Express Web Systems, Inc.	2019-06-19
72.52.192.240	Lansing - United States	Liquid Web, L.L.C	2011-12-19

ViewDNS.info > Tools > IP History

Shows a historical list of IP addresses a given domain name has been hosted on as well as where that IP address is geographically located, and the owner of that IP address.

Domain (e.g. domain.com):

 GO

IP history results for purchase.org.

IP Address	Location	IP Address Owner	Last seen on this IP
172.67.197.177	United States	Cloudflare, Inc.	2021-02-27
104.21.92.201	United States	Cloudflare, Inc.	2021-02-27
104.27.185.115	United States	Cloudflare, Inc.	2021-01-14
104.27.184.115	United States	Cloudflare, Inc.	2021-01-14
206.196.110.108	St Louis - United States	Rose Web Services LLC	2017-11-03
67.43.1.187	Lansing - United States	Liquid Web, L.L.C	2013-04-19
72.52.193.127	Lansing - United States	Liquid Web, L.L.C	2012-11-16

- Sau khi ghi vào, ta hoàn thành

Room progress (92%)

Task 6 ✓ Taking A Peek Under The Hood Of A Website

Task 7 ✓ Final Exam: Connect the Dots

Experienced OSINT researchers will tell you that chasing rabbit holes all day and night without being able to make some solid connections is not OSINT.

OSINT refers to the patterns that start to emerge as we connect the dots in the analysis of the data.

Congrats! you found that our target, heat[.]net, links to an interesting external site. A question remains though: *Why???*

There is no affiliate code in the link, so there is no obvious financial connection between the two. Maybe there's another kind of connection.

This is your final exam, and there is exactly one question.

Get busy!

Answer the questions below

Use the tools in Task 4 to confirm the link between the two sites. Try hard to figure it out without the hint.

Liquid Web, L.L.C ✓ Correct Answer Hint

Task 8 ○ Debriefing

Task 9 ○ Wrap-up

Task 8: Debriefing và Task 9: Wrap-up

- 2 tasks này cung cấp cho ta thêm những thông tin hữu ích và cần thiết trong việc osint, ta chỉ cần submit trống là xong.

Lab 2: Tổng quan các lỗ hổng web thường gặp (P2)

36

https://tryhackme.com/r/room/webosint

Woop woop! Your answer is correct



Congratulations on completing WebOSINT!!! 🎉

Points earned 🔥 720	Completed tasks ✅ 9	Room type 📋 Challenge	Difficulty 📶 Easy	Streak 🔥 1
------------------------	------------------------	--------------------------	----------------------	---------------

🗨️ Leave Feedback

Close

9:39 PM
11/20/2024

<https://academy.hackthebox.com/module/details/54>

Task 1:

Directory Fuzzing

Now that we understand the concept of Web Fuzzing and know our wordlist, we should be ready to start using **ffuf** to find website directories.

Chạy dò

```
File Actions Edit View Help
[Status: 200, Size: 986, Words: 423, Lines: 56, Duration: 3219ms]
:: Progress: [87664/87664] :: Job [1/1] :: 85 req/sec :: Duration: [0:00:03] :: Errors: 87649 ::

(kali@kali)-[~/Downloads]
$ ffuf -w directory-list-2.3-small.txt:FUZZ -u http://83.136.254.197:44510/FUZZ

v2.1.0-dev

:: Method      : GET
:: URL         : http://83.136.254.197:44510/FUZZ
:: Wordlist    : FUZZ: /home/kali/Downloads/directory-list-2.3-small.txt
:: Follow redirects : false
:: Calibration : false
:: Timeout     : 10
:: Threads    : 40
:: Matcher     : Response status: 200-299,301,302,307,401,403,405,500

[Status: 200, Size: 986, Words: 423, Lines: 56, Duration: 229ms]
[Status: 200, Size: 986, Words: 423, Lines: 56, Duration: 232ms]
[Status: 200, Size: 986, Words: 423, Lines: 56, Duration: 234ms]
[Status: 200, Size: 986, Words: 423, Lines: 56, Duration: 229ms]
[Status: 200, Size: 986, Words: 423, Lines: 56, Duration: 232ms]
[Status: 200, Size: 986, Words: 423, Lines: 56, Duration: 232ms]
[Status: 200, Size: 986, Words: 423, Lines: 56, Duration: 238ms]
[Status: 200, Size: 986, Words: 423, Lines: 56, Duration: 321ms]
forum [Status: 301, Size: 325, Words: 20, Lines: 10, Duration: 230ms]
[Status: 200, Size: 986, Words: 423, Lines: 56, Duration: 1295ms]
[Status: 200, Size: 986, Words: 423, Lines: 56, Duration: 1298ms]
[Status: 200, Size: 986, Words: 423, Lines: 56, Duration: 2298ms]
[Status: 200, Size: 986, Words: 423, Lines: 56, Duration: 2301ms]
[Status: 200, Size: 986, Words: 423, Lines: 56, Duration: 2298ms]
[Status: 200, Size: 986, Words: 423, Lines: 56, Duration: 3302ms]
blog [Status: 301, Size: 324, Words: 20, Lines: 10, Duration: 4303ms]
[Status: 200, Size: 986, Words: 423, Lines: 56, Duration: 237ms]
```

Kết quả:

+ 0

In addition to the directory we found above, there is another directory that can be found. What is it?

forum

Task 2:

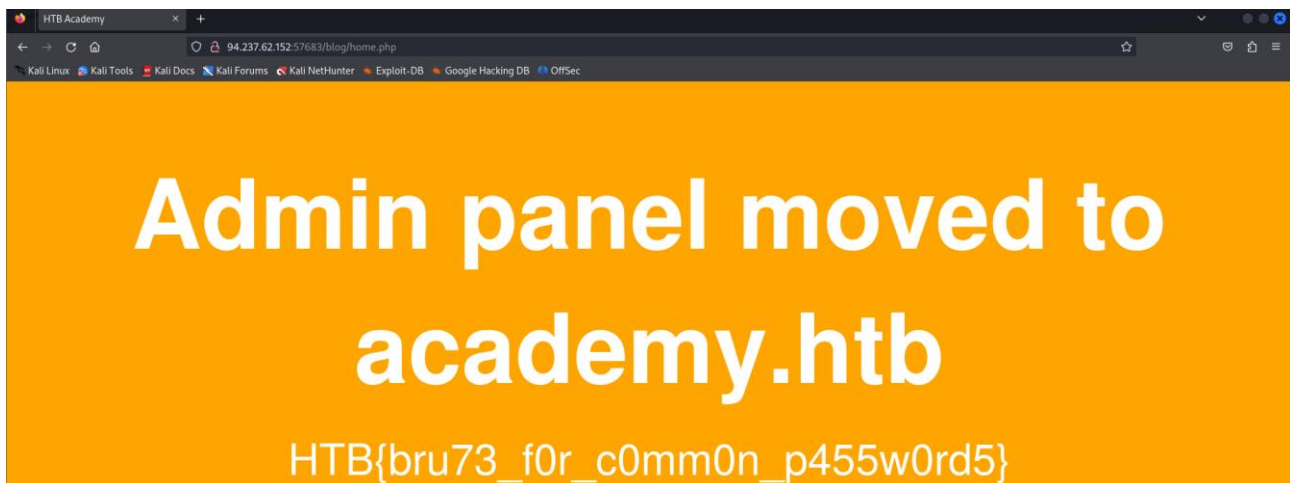
Chạy dò các file *.php trong folder /blog:

```
(dducktai@kali) ~$ ffuf -w /usr/share/dirbuster/wordlists/directory-list-2.3-small.txt -u http://94.237.62.152:57683/blog/FUZZ.php -mc 200,301,302,403

v2.1.0-dev

:: Method      : GET
:: URL         : http://94.237.62.152:57683/blog/FUZZ.php
:: Wordlist     : FUZZ: /usr/share/dirbuster/wordlists/directory-list-2.3-small.txt
:: Follow redirects : false
:: Calibration : false
:: Timeout     : 10
:: Threads     : 40
:: Matcher     : Response status: 200,301,302,403

# This work is licensed under the Creative Commons [Status: 200, Size: 0, Words: 1, Lines: 1, Duration: 198ms]
# on atleast 3 different hosts [Status: 200, Size: 0, Words: 1, Lines: 1, Duration: 198ms]
# Suite 300, San Francisco, California, 94105, USA. [Status: 200, Size: 0, Words: 1, Lines: 1, Duration: 198ms]
# license, visit http://creativecommons.org/licenses/by-sa/3.0/ [Status: 200, Size: 0, Words: 1, Lines: 1, Duration: 202ms]
# Priority ordered case sensitive list, where entries were found [Status: 200, Size: 0, Words: 1, Lines: 1, Duration: 204ms]
# home [Status: 200, Size: 1046, Words: 438, Lines: 58, Duration: 202ms]
# Copyright 2007 James Fisher [Status: 200, Size: 0, Words: 1, Lines: 1, Duration: 206ms]
# [Status: 200, Size: 0, Words: 1, Lines: 1, Duration: 207ms]
# [Status: 403, Size: 281, Words: 20, Lines: 10, Duration: 207ms]
# Attribution-Share Alike 3.0 License. To view a copy of this [Status: 200, Size: 0, Words: 1, Lines: 1, Duration: 218ms]
# or send a letter to Creative Commons, 171 Second Street, [Status: 200, Size: 0, Words: 1, Lines: 1, Duration: 218ms]
# directory-list-2.3-small.txt [Status: 200, Size: 0, Words: 1, Lines: 1, Duration: 218ms]
# [Status: 200, Size: 0, Words: 1, Lines: 1, Duration: 226ms]
# index [Status: 200, Size: 0, Words: 1, Lines: 1, Duration: 223ms]
# [Status: 200, Size: 0, Words: 1, Lines: 1, Duration: 222ms]
# [Status: 200, Size: 0, Words: 1, Lines: 1, Duration: 223ms]
```



Kết quả:

+ 1

Try to use what you learned in this section to fuzz the '/blog' directory and find all pages. One of them should contain a flag. What is the flag?

HTB{bru73_f0r_c0mm0n_p455w0rd5}

Task 3:

```
kali@kali: ~/Downloads
File Actions Edit View Help
(kali@kali)~[~/Downloads]
$ ffuf -w directory-list-2.3-small.txt:FUZZ -u http://94.237.51.81:47469/FUZZ -recursion -recursion-depth 1
-e .php -v

v2.1.0-dev

:: Method      : GET
:: URL         : http://94.237.51.81:47469/FUZZ
:: Wordlist     : FUZZ: /home/kali/Downloads/directory-list-2.3-small.txt
:: Extensions  : .php
:: Follow redirects : false
:: Calibration  : false
:: Timeout     : 10
:: Threads     : 40
:: Matcher     : Response status: 200-299,301,302,307,401,403,405,500

[Status: 403, Size: 280, Words: 20, Lines: 10, Duration: 232ms]
| URL | http://94.237.51.81:47469/.php
* FUZZ: .php

[Status: 403, Size: 280, Words: 20, Lines: 10, Duration: 234ms]
| URL | http://94.237.51.81:47469/.php
* FUZZ: .php

[Status: 403, Size: 280, Words: 20, Lines: 10, Duration: 235ms]
| URL | http://94.237.51.81:47469/.php
* FUZZ: .php

[Status: 200, Size: 986, Words: 423, Lines: 56, Duration: 233ms]
| URL | http://94.237.51.81:47469/
```

```
SecLists/Discovery/Web-Content x HTB Academy x 94.237.51.81:47469/forum/flag.php x +
94.237.51.81:47469/forum/flag.php
Kali Linux Kali Tools Kali Docs Kali Forums Kali NetHunter Exploit-DB Google Hacking DB OffSec
HTB{fuzz1n6_7h3_w3b!}
```

Kết quả:

Target(s): **94.237.51.81:47469**

Life Left: 72 minute(s)

+1 Try to repeat what you learned so far to find more files/directories. One of them should give you a flag. What is the content of the flag?

HTB{fuzz1n6_7h3_w3b!}

Submit Hint

Task 4:

```
(dducktai@kali)-[~]
$ ffuf -w /home/dducktai/subdomains-top1million-5000.txt:FUZZ -u https://FUZZ.inlanefreight.com/ -mc 200,301,302,403

v2.1.0-dev

:: Method      : GET
:: URL         : https://FUZZ.inlanefreight.com/
:: Wordlist     : FUZZ: /home/dducktai/subdomains-top1million-5000.txt
:: Follow redirects : false
:: Calibration  : false
:: Timeout      : 10
:: Threads     : 40
:: Matcher     : Response status: 200,301,302,403

my      [Status: 301, Size: 0, Words: 1, Lines: 1, Duration: 2032ms]
www     [Status: 200, Size: 22266, Words: 2903, Lines: 316, Duration: 3242ms]
support [Status: 301, Size: 0, Words: 1, Lines: 1, Duration: 2229ms]
ns3     [Status: 301, Size: 0, Words: 1, Lines: 1, Duration: 2344ms]
blog    [Status: 301, Size: 0, Words: 1, Lines: 1, Duration: 2336ms]
customer [Status: 301, Size: 0, Words: 1, Lines: 1, Duration: 2208ms]
```

Kết quả:

+0 Try running a sub-domain fuzzing test on 'inlanefreight.com' to find a customer sub-domain portal.
What is the full domain of it?
customer.inlanefreight.com

Task 5:

Chạy lệnh dò subdomain:

```
kali@kali: ~/Downloads
File Actions Edit View Help
(kali@kali)-[~/Downloads]
$ ffuf -w subdomains-top1million-5000.txt:FUZZ -u http://94.237.51.81:47469/ -H 'Host: FUZZ.academy.htb'

v2.1.0-dev

:: Method      : GET
:: URL         : http://94.237.51.81:47469/
:: Wordlist     : FUZZ: /home/kali/Downloads/subdomains-top1million-5000.txt
:: Header      : Host: FUZZ.academy.htb
:: Follow redirects : false
:: Calibration  : false
:: Timeout      : 10
:: Threads     : 40
:: Matcher     : Response status: 200-299,301,302,307,401,403,405,500

ns2     [Status: 200, Size: 986, Words: 423, Lines: 56, Duration: 287ms]
dev     [Status: 200, Size: 986, Words: 423, Lines: 56, Duration: 290ms]
ns      [Status: 200, Size: 986, Words: 423, Lines: 56, Duration: 268ms]
cp      [Status: 200, Size: 986, Words: 423, Lines: 56, Duration: 264ms]
mail    [Status: 200, Size: 986, Words: 423, Lines: 56, Duration: 682ms]
ns1     [Status: 200, Size: 986, Words: 423, Lines: 56, Duration: 691ms]
beta    [Status: 200, Size: 986, Words: 423, Lines: 56, Duration: 244ms]
pop3    [Status: 200, Size: 986, Words: 423, Lines: 56, Duration: 253ms]
vpn     [Status: 200, Size: 986, Words: 423, Lines: 56, Duration: 283ms]
mx      [Status: 200, Size: 986, Words: 423, Lines: 56, Duration: 273ms]
support [Status: 200, Size: 986, Words: 423, Lines: 56, Duration: 324ms]
shop    [Status: 200, Size: 986, Words: 423, Lines: 56, Duration: 323ms]
```

ns3	[Status: 200, Size: 986, Words: 423, Lines: 56, Duration: 3007ms]
autoconfig	[Status: 200, Size: 986, Words: 423, Lines: 56, Duration: 3005ms]
new	[Status: 200, Size: 986, Words: 423, Lines: 56, Duration: 3039ms]
pop	[Status: 200, Size: 986, Words: 423, Lines: 56, Duration: 3077ms]
test	[Status: 200, Size: 0, Words: 1, Lines: 1, Duration: 3078ms]
ns4	[Status: 200, Size: 986, Words: 423, Lines: 56, Duration: 3082ms]
www2	[Status: 200, Size: 986, Words: 423, Lines: 56, Duration: 3082ms]
www	[Status: 200, Size: 986, Words: 423, Lines: 56, Duration: 3081ms]
staging	[Status: 200, Size: 986, Words: 423, Lines: 56, Duration: 1181ms]
search	[Status: 200, Size: 986, Words: 423, Lines: 56, Duration: 1123ms]
crm	[Status: 200, Size: 986, Words: 423, Lines: 56, Duration: 1059ms]
chat	[Status: 200, Size: 986, Words: 423, Lines: 56, Duration: 1176ms]
ads	[Status: 200, Size: 986, Words: 423, Lines: 56, Duration: 1011ms]

Kết quả:

+ 0 Try running a VHost fuzzing scan on 'academy.htb', and see what other VHosts you get. What other VHosts did you get?

test.academy.htb

Submit Hint

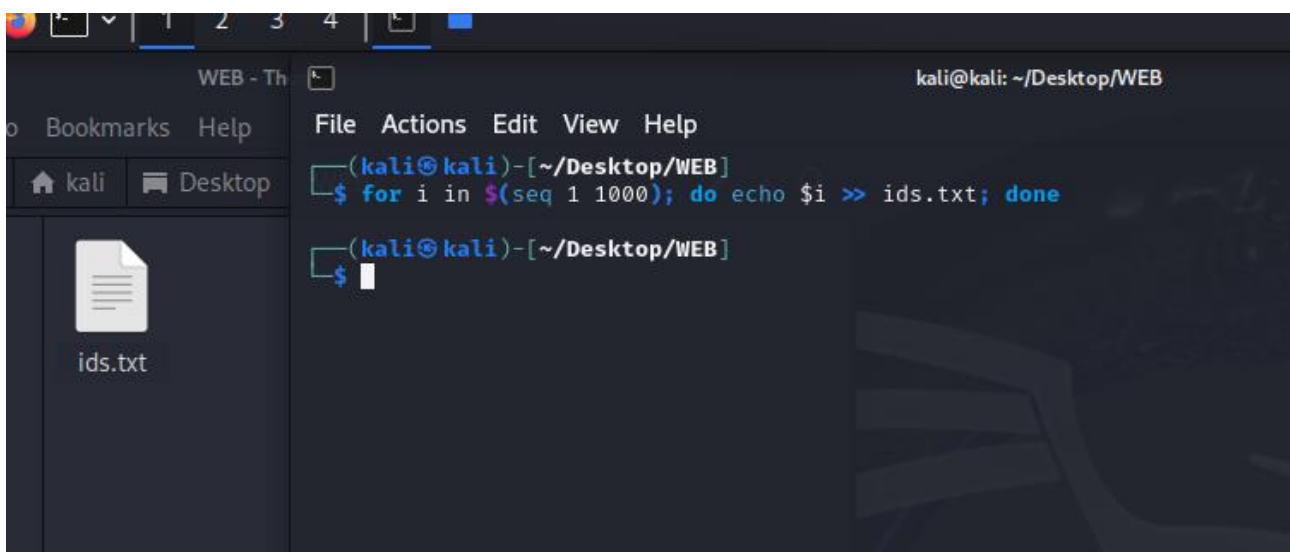
Task 6:

+ 0 Using what you learned in this section, run a parameter fuzzing scan on this page. what is the parameter accepted by this webpage?

user

Task 7:

Tạo file ids.txt



Chạy lệnh nhận thấy 0

```

kali@kali: ~/Desktop/WEB
File Actions Edit View Help

(kali@kali)~[~/Desktop/WEB]
$ ffuf -w ids.txt:FUZZ -u http://83.136.254.197:44510 -X POST -d 'id=FUZZ' -H 'Content-Type: application/x-www-form-urlencoded' -fs 768

v2.1.0-dev

:: Method      : POST
:: URL         : http://83.136.254.197:44510
:: Wordlist     : FUZZ: /home/kali/Desktop/WEB/ids.txt
:: Header      : Content-Type: application/x-www-form-urlencoded
:: Data        : id=FUZZ
:: Follow redirects : false
:: Calibration  : false
:: Timeout      : 10
:: Threads     : 40
:: Matcher      : Response status: 200-299,301,302,307,401,403,405,500
:: Filter       : Response size: 768

22      [Status: 200, Size: 986, Words: 423, Lines: 56, Duration: 289ms]
6       [Status: 200, Size: 986, Words: 423, Lines: 56, Duration: 294ms]
2       [Status: 200, Size: 986, Words: 423, Lines: 56, Duration: 294ms]
32      [Status: 200, Size: 986, Words: 423, Lines: 56, Duration: 297ms]
1       [Status: 200, Size: 986, Words: 423, Lines: 56, Duration: 296ms]
23      [Status: 200, Size: 986, Words: 423, Lines: 56, Duration: 379ms]
41      [Status: 200, Size: 986, Words: 423, Lines: 56, Duration: 240ms]
42      [Status: 200, Size: 986, Words: 423, Lines: 56, Duration: 236ms]
43      [Status: 200, Size: 986, Words: 423, Lines: 56, Duration: 236ms]

```

----- HẾT -----